



تقرير تقييم مستوى الكفاءة الرقابية

الأمانة العامة للمجلس الصحي السعودي



محتويات التقرير

1	محتويات التقرير
2	شكر وتقدير
2	أصحاب المصلحة الرئيسيين
2	توزيع التقرير
3	المصطلحات والتعاريف
5	أولاً: الملخص التنفيذي
5	1. مقدمة
5	2. هدف التقرير
5	3. نطاق عمل التقييم
6	4. نطاقات التحول للرقابة الذاتية
6	5. مسؤولية الأمانة العامة للمجلس الصحي السعودي في التحول للرقابة الذاتية
6	6. مسؤولية فريق عمل تقييم مستوى الكفاءة الرقابية
7	7. الافتراضات (Assumptions)
7	8. كافة القيود على عملية التقييم (Scope Limitations)
8	9. نتائج التقييم النهائية
10	10. قائمة الضوابط الرقابية التي تم تقييمها
14	ثانياً: ملاحظات التقييم – فعالية الإدارات الرقابية والضوابط العامة لتقنية المعلومات (ITGCs)
33	ثالثاً: ملاحظات التقييم - العمليات الخاضعة للرقابة المالية
51	رابعاً: أنشطة إدارة التغيير في عملية التحول للرقابة الذاتية
55	خامساً: الخطة الزمنية لرفع مستوى الكفاءة الرقابية
57	ملحق (1): منهجية تصعيد التأخر في تنفيذ الخطط التصحيحية ورفع طلبات التمديد
58	ملحق (2): إطار تقييم مستوى الكفاءة الرقابية

شكر وتقدير

تتقدم وزارة المالية بخالص الشكر والتقدير إلى الأمانة العامة للمجلس الصحي السعودي تميماً لجهودهم وتعاونهم المثمر أثناء العمل الميداني مع فريق عمل تقييم مستوى الكفاءة الرقابية بوزارة المالية والتي كان لها أثر واضح وملحوس في تحقيق الأهداف المنشودة لهذا التقرير.

أصحاب المصلحة الرئيسيين

الاسم	المسمى	الجهة التابعة
سعادة الأستاذ/ سعود آل بريك	وكيل للإيرادات العامة ووكيل للشؤون المالية والحسابات المكلف / راعي التحول	وزارة المالية
سعادة الأستاذ/ محمد السليم	مدير عام الإدارة العامة للموارد المؤسسية / راعي التحول	الأمانة العامة للمجلس الصحي السعودي

توزيع التقرير

الجدول أدناه يوضح قائمة بمستلمي نسخة من هذا التقرير:

نسخة إلى:		
سعادة الأستاذ/ سعود آل بريك	وكيل للإيرادات العامة ووكيل للشؤون المالية والحسابات المكلف / راعي التحول	وزارة المالية
سعادة الأستاذ/ محمد السليم	مدير عام الإدارة العامة للموارد المؤسسية / راعي التحول	الأمانة العامة للمجلس الصحي السعودي
سعادة الأستاذ/ عبدالله آل مهذل	الوكيل المساعد للسياسات والحوكمة والوكيل المساعد للرقابة المالية المكلف / مالك التحول	وزارة المالية
سعادة الأستاذ/ محمد الشريف	مدير الإدارة المالية / ضابط اتصال التحول	الأمانة العامة للمجلس الصحي السعودي

المصطلحات والتعاريف

المصطلح	التعريف
الرقابة المالية	السياسات والإجراءات والوسائل التي يتم من خلالها التحقق من: - سلامة العمليات التي لها أثر مالي على الميزانية والقوائم المالية - الحسابات الختامية الخاصة بالجهة - كفاءة وفاعلية نظام الرقابة الداخلي - مدى التزام الجهة بالأنظمة واللوائح والأدلة والتعليمات والقرارات ذات الصلة
نظام الرقابة الداخلي	الممارسات التي تقوم بها الجهة لضمان تحقيق أهدافها الاستراتيجية والتشغيلية ودقة التقارير والالتزام بالأنظمة واللوائح
الضوابط الرقابية	الإجراءات التي تطبقها الجهة ومنسوبوها كأداة من أدوات الرقابة الداخلية للحد والتخفيف من المخاطر التي تؤثر على تحقيق الأهداف، وتشمل الإجراءات والضوابط التي تطبقها على كافة المستويات الإدارية والعمليات والمدخلات والمخرجات بجميع أنواعها
الكفاءة الرقابية	مدى كفاية وفاعلية أدوات الرقابة الداخلية في الجهة، ويكون تقييم درجة الكفاءة الرقابية بناءً على تقييم تصميم وتطبيق الضوابط الرقابية في هذه الجهات
الرقابة الذاتية	أسلوب رقابي تكون فيه الجهة مسؤولة عن الرقابة على عملياتها ذات الأثر المالي من خلال منسوبيها ووفقاً لإجراءات رقابية داخلية يتم تقييمها واعتمادها من الوزارة
الخطة التصحيحية	خطة عمل تتضمن جميع الإجراءات التي يجب اتخاذها من قبل الجهة الحكومية لمعالجة وتطوير الضوابط الرقابية بهدف تحسين ورفع الكفاءة الرقابية لدى الجهة
أنشطة إدارة التغيير	مجموعة من الأنشطة التي تعنى بزيادة الوعي والمعرفة وبناء القدرات لدى منسوبي الجهات الحكومية عن عملية التحول للرقابة الذاتية.
القيود على عملية التقييم	عدم تمكن فريق عمل تقييم مستوى الكفاءة الرقابية من الحكم على مدى كفاءة الضابط الرقابي نتيجة وجود بعض القيود في توفير متطلبات التقييم اللازمة من قبل الجهة الحكومية.

أولاً: الملخص التنفيذي

أولاً: الملخص التنفيذي

1. مقدمة

انطلاقاً من دور وزارة المالية في رفع كفاءة الرقابة المالية وتعزيز المساءلة والشفافية في القطاع الحكومي واستناداً على الأنظمة واللوائح والتعليمات والقرارات والاطر والمعايير ذات الصلة تقوم هذه الوزارة بتقييم مستوى الكفاءة الرقابية في الجهات الحكومية لتهيئتها بهدف تطبيق أسلوب الرقابة الذاتية، وذلك من خلال تحديد أوجه التحسين في البيئة الرقابية وتقديم التوصيات اللازمة بما يسهم في تطوير ورفع مستوى الكفاءة الرقابية.

2. هدف التقرير

تم إعداد هذا التقرير لهدف عرض نتائج تقييم مستوى الكفاءة الرقابية في الأمانة العامة للمجلس الصحي السعودي مع الخطط التصحيحية اللازمة لتمكينها من التحول الى تطبيق أسلوب الرقابة الذاتية.

3. نطاق عمل التقييم

شمل نطاق عمل تقييم مستوى الكفاءة الرقابية تقييم مجموعة من الضوابط الرقابية المرتبطة بمحورين رئيسيين هما:

- **المحور الأول: فعالية الإدارات الرقابية والضوابط العامة لتقنية المعلومات (ITGCs)، والذي** يشمل الإدارات الرقابية في الجهة متمثلة في الخطين الثاني والثالث، بالإضافة إلى مجموعة من الضوابط الرقابية العامة لتقنية المعلومات والمرتبطة بكلٍ من المجالات أو الأنشطة التقنية التالية: (حوكمة تقنية المعلومات، إدارة التغيير، عمليات تقنية المعلومات، أمن المعلومات إدارة هويات الدخول والصلاحيات).
- **المحور الثاني: العمليات الخاضعة للرقابة المالية،** حيث تم تصنيف العمليات المالية التي تخضع لرقابة الممثل المالي لوزارة المالية في الجهة الحكومية إلى أربع مجموعات / فئات رئيسية وهي:

أساليب الشراء وفحص العروض
حسابات التسوية

تعويضات العاملين والمكافآت
الصرف وآثار تنفيذ العقود

والتي ترتبط بالأنشطة والعمليات الرئيسية التالية: (المالية والميزانية، المشتريات والعقود، المستودعات ومراقبة المخزون، الموارد البشرية) كما أن الفترة الزمنية المغطاة في عملية التقييم هي من (1 يناير 2025م وحتى 31 ديسمبر 2025م).

4. نطاقات التحول للرقابة الذاتية

المعايير	نطاق
- عدم تحقيق معدل 100% فى أياً من العمليات الخاضعة للرقابة المالية - عدم تحقيق معدل 100% فى محور فعالية الإدارات الرقابية والضوابط العامة لتقنية المعلومات	عدم إمكانية التحول للرقابة الذاتية
- تحقيق معدل 100% فى بعض العمليات الخاضعة للرقابة المالية - تحقيق معدل 100% فى محور فعالية الإدارات الرقابية والضوابط العامة لتقنية المعلومات	إمكانية التحول الجزئي للرقابة الذاتية
- تحقيق معدل 100% فى جميع العمليات الخاضعة للرقابة المالية - تحقيق معدل 100% فى محور فعالية الإدارات الرقابية والضوابط العامة لتقنية المعلومات	إمكانية التحول الكلي للرقابة الذاتية

5. مسؤولية الأمانة العامة للمجلس الصحي السعودي في التحول للرقابة الذاتية

- إن الإدارات المعنية بالأمانة العامة للمجلس الصحي السعودي هي المسؤولة عن إنشاء والاحتفاظ وتحديد الأهداف التنظيمية والتشغيلية وتصميم وتطوير أنظمة رقابية فعالة لتحقيق أهدافها وغاياتها والمحافظة عليها.
- كما أن الأمانة العامة للمجلس الصحي السعودي هي المسؤولة عن إنشاء بيئة رقابية تعزز الوعي بأهمية الإجراءات الرقابية والمحافظة عليها وحمايتها.
- أيضاً فإن الإدارات المعنية بالأمانة العامة للمجلس الصحي السعودي مسؤولة عن تطبيق الخطط التصحيحية الواردة في هذا التقرير وفقاً للجدول الزمني المحدد والمتفق عليه على أن يتم تزويد فريق عمل تقييم مستوى الكفاءة الرقابية بالتحديثات اللازمة عن حالة تنفيذ هذه الخطط التصحيحية ومتطلبات التقييم اللازمة.

6. مسؤولية فريق عمل تقييم مستوى الكفاءة الرقابية

- التزم فريق عمل التقييم بوزارة المالية بتنفيذ إجراءات تقييم الضوابط الرقابية وفقاً للمنهجية المعتمدة، كما يلتزم أيضاً بالمتابعة الدورية على حالة تطبيق الخطط التصحيحية مع ضابط الاتصال المعين في الأمانة العامة للمجلس الصحي السعودي وفق الخطة الزمنية المعتمدة في هذا التقرير.

7. الافتراضات (Assumptions)

- إن تقييم مستوى الكفاءة الرقابية مستند على مبدأ التأكيد المعقول (Reasonable Assurance) في اختيار وتقييم عينات ومتطلبات الفحص في الأنشطة محل التقييم والمشمولة في النطاق الزمني المحدد ضمن نطاق العمل.
- إن النتائج ضمن هذا التقرير مبنية على الوثائق والمستندات والمعلومات المقدمة لفريق عمل تقييم مستوى الكفاءة الرقابية من قبل الإدارات المعنية خلال فترة تنفيذ التقييم، وعليه فإن فريق العمل لم يقيم بتحديث أو تعديل بيانات هذا التقرير لإظهار أحداث أو ظروف وقعت بعد ذلك التاريخ.
- المعلومات التي تم تزويدها لفريق عمل تقييم مستوى الكفاءة الرقابية خلال الاجتماعات مع الأنشطة محل التقييم هي معلومات صحيحة ودقيقة، والمستندات التي تم تزويد فريق عمل التقييم بها ممثلة لطبيعة العمليات التي تتم في تلك الأنشطة، حيث أن لها أثراً كبيراً على تقييم فريق العمل للضوابط الرقابية الخاصة بكل نشاط / عملية.
- في حال أنه لم يتم تزويد فريق عمل تقييم مستوى الكفاءة الرقابية بالمتطلبات اللازمة لتقييم الضوابط الرقابية أو أيّاً منها، سيتم التحفظ على تقييم تلك الضوابط الرقابية مما ينعكس سلباً على النتيجة النهائية لمستوى الكفاءة الرقابية في الجهة ويؤدي إلى عدم إمكانية التحول للرقابة الذاتية.
- تعتبر جميع النتائج المذكورة في هذا التقرير مبنية على نتائج تقييم الضوابط الرقابية وفقاً للوثائق والمستندات والمعلومات التي تم تزويد فريق العمل بها خلال النطاق الزمني المحدد، وعليه فإن تلك النتائج قابلة للتعديل أو الحذف أو الإضافة في حال وجود أي أدلة أو معلومات أخرى إضافية، أو في حال استحداث ضابط رقابي آخر مناسب.

8. كافة القيود على عملية التقييم (Scope Limitations)

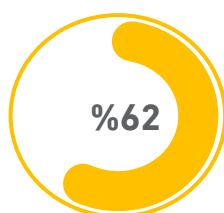
- لم يواجه فريق التقييم لمستوى الكفاءة الرقابية بوزارة المالية أي قيود تُعيق إبداء الرأي في الضوابط الرقابية، وقد تم الاطلاع على كافة البيانات والمستندات ذات العلاقة.

9. نتائج التقييم النهائية

1. نظرة عامة على نتائج التقييم التفصيلية (على مستوى الأنشطة / العمليات)

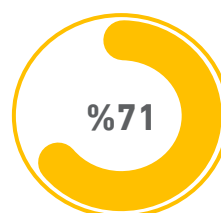
- المحور الأول: تقييم فعالية الإدارات الرقابية والضوابط العامة لتقنية المعلومات (ITGCs):

الضوابط العامة لتقنية المعلومات



يحتاج الى تحسين

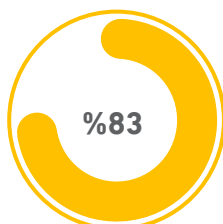
الإدارات الرقابية



يحتاج الى تحسين

- المحور الثاني: تقييم فعالية العمليات الخاضعة للرقابة المالية:

الموارد البشرية



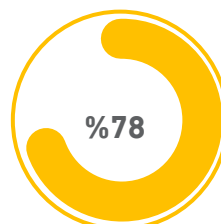
يحتاج الى تحسين

المستودعات ومراقبة المخزون



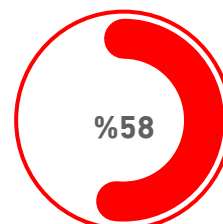
غير مرضي

المشتريات والعقود

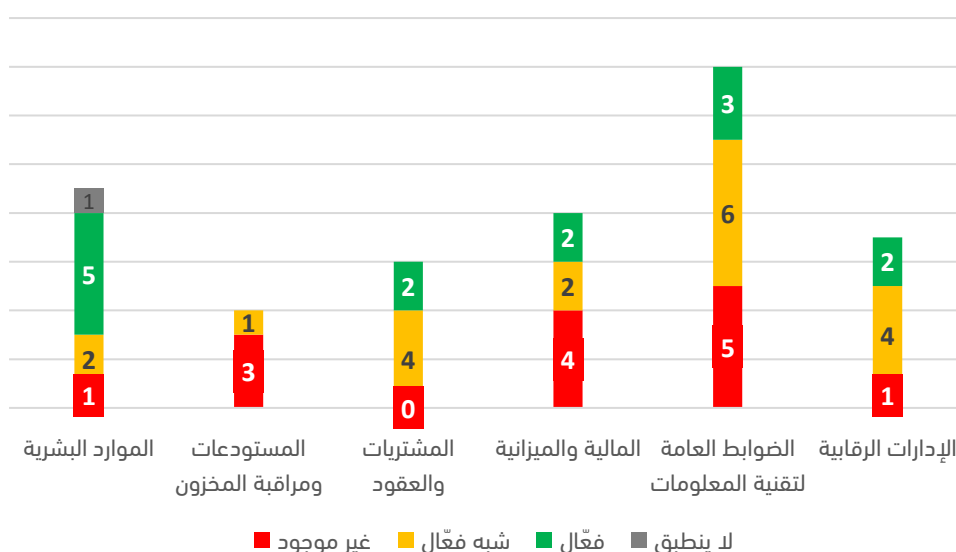


يحتاج الى تحسين

المالية والميزانية



غير مرضي



2. نتائج التقييم الكلية (على مستوى محاور التقييم)

معدل التقييم	محور التقييم
65%	المحور الأول: فعالية الإدارات الرقابية والضوابط العامة لتقنية المعلومات (ITGCs)
83%	تعويضات العاملين والمكافآت
50%	الصرف وآثار تنفيذ العقود
78%	أساليب الشراء وفحص العروض
58%	حسابات التسوية

3. رأي التقييم النهائي:

بناءً على نتائج تقييم الضوابط الرقابية وفقاً لمحاور التقييم "مع الأخذ بعين الاعتبار الافتراضات والقيود وفترة التغطية التي تم الإشارة إليها أعلاه"، واستناداً على مبدأ التأكيد المعقول (Reasonable Assurance) في اختيار وتقييم عينات ومتطلبات الفحص:

- فإنه لا يمكن تطبيق التحول للرقابة الذاتية في الوقت الحالي في الأمانة العامة للمجلس الصحي السعودي نظراً لعدم تحقيق معدل التقييم المستهدف في محاور التقييم التالية:
 - المحور الأول: فعالية الإدارات الرقابية والضوابط العامة لتقنية المعلومات
 - المحور الثاني: العمليات الخاضعة للرقابة المالية
- (للاطلاع على المعدلات المستهدفة يرجى الرجوع للفقرة (4) من هذا الملخص التنفيذي "نطاقات التحول للرقابة الذاتية").

كما ينوه فريق عمل تقييم مستوى الكفاءة الرقابية على أهمية النقاط التالية:

- مهمة الحفاظ على مستوى كفاءة وفعالية نظام الرقابة الداخلي تقع على عاتق الأمانة العامة للمجلس الصحي السعودي دون أدنى مسؤولية على فريق عمل وزارة المالية.
 - تعتمد استمرارية تطبيق أسلوب الرقابة الذاتية في الأمانة العامة للمجلس الصحي السعودي على استمرارية كفاءة وفعالية نظام الرقابة الداخلي.
- يجب على الأمانة العامة للمجلس الصحي السعودي تقديم الدعم اللازم لفريق عمل مستوى الكفاءة الرقابية خلال مرحلة تنفيذ الخطط التصحيحية وخلال زيارات التقييم الدورية المستمرة.

10. قائمة الضوابط الرقابية التي تم تقييمها

الرمز المرجعي	الضابط	التقييم	العملية / النشاط
1.1	استقلالية نشاط المراجعة الداخلية في الجهة واستقلالية مدير عام المراجعة الداخلية.	شبه فعال	الإدارات الرقابية (الخطين الثاني والثالث)
1.2	خطة سنوية للمراجعة الداخلية على مستوى استراتيجي أو تشغيلي بناء على نتائج تقييم المخاطر تشمل: العمليات التالية (المالية والميزانية، المشتريات والعقود، المستودعات ومراقبة المخزون، الموارد البشرية، تقنية وأمن المعلومات).	شبه فعال	الإدارات الرقابية (الخطين الثاني والثالث)
1.3	توثيق الإجراءات والصلاحيات المرتبطة بالعمليات الخاضعة للرقابة المالية.	غير موجود	الإدارات الرقابية (الخطين الثاني والثالث)
1.4	توثيق واعتماد سياسة خاصة بتعويضات ومكافآت أعضاء اللجان الإشرافية / التنفيذية لدى الجهة والالتزام بها.	فعال	الإدارات الرقابية (الخطين الثاني والثالث)
1.5	مصفوفة صلاحيات إدارية ومالية محدثة معتمدة من قبل صاحب الصلاحية.	فعال	الإدارات الرقابية (الخطين الثاني والثالث)
1.6	تقييم المخاطر المرتبطة بالعمليات التالية (المالية والميزانية، المشتريات والعقود، المستودعات ومراقبة المخزون، الموارد البشرية، تقنية وأمن المعلومات) بشكل دوري وتحديد وتوثيق خطط معالجة تلك المخاطر مع الإدارات المعنية	شبه فعال	الإدارات الرقابية (الخطين الثاني والثالث)
1.7	قنوات خاصة باستلام البلاغات عن حالات الاحتيال والفساد والمخالفات المالية وفرزها وإدارتها.	شبه فعال	الإدارات الرقابية (الخطين الثاني والثالث)
1.8	تطوير سياسات وإجراءات موثقة ومعتمدة وشاملة لجميع العمليات التقنية في الجهة الحكومية	شبه فعال	الضوابط العامة لتقنية المعلومات (ITGCs)
1.9	أخذ الموافقات اللازمة على إنشاء حساب مستخدم جديد أو تعديل صلاحيات حساب مستخدم موجود على النظام المالي، حسب مصفوفة الصلاحيات المعتمدة	شبه فعال	الضوابط العامة لتقنية المعلومات (ITGCs)
1.10	إلغاء صلاحيات المستخدمين من النظام بالوقت المناسب وفور انتهاء حاجة الموظف لتلك الصلاحيات لأي سبب كان (وفاة، استقالة، انتقال، إعاره).	فعال	الضوابط العامة لتقنية المعلومات (ITGCs)
1.11	أخذ الموافقات اللازمة على إعطاء صلاحيات "مشرف" وصلاحيات مميزة للوصول إلى النظام المالي وقواعد بيانات النظام لعدد محدود من المستخدمين حسب مصفوفة الصلاحيات المعتمدة	غير موجود	الضوابط العامة لتقنية المعلومات (ITGCs)
1.12	تم المراجعة على صلاحيات المستخدمين وصلاحيات الوصول periodic user review على النظام بشكل دوري.	غير موجود	الضوابط العامة لتقنية المعلومات (ITGCs)
1.13	وضع معايير تحديد كلمة المرور على النظام المالي بحيث تستند على أفضل الممارسات منها: (التعقيد، الطول، التاريخ، انتهاء الصلاحية، تعليق الدخول).	فعال	الضوابط العامة لتقنية المعلومات (ITGCs)
1.14	تسجيل وتصنيف التغييرات المنفذة على النظام المالي بعد أخذ الموافقات اللازمة والتواؤم مع المجلس الاستشاري للتغيير (CAB) وإجراء اختبارات الجودة اللازمة.	غير موجود	الضوابط العامة لتقنية المعلومات (ITGCs)
1.15	توفر بيانات التطوير والاختبار والإنتاج (Development, testing and Production) وتوزيع المهام وفصلها على المستخدمين المصرح لهم إجراء التغييرات في البيانات المختلفة بحيث يكون لكل بيئة مستخدمين مخولين بالقيام بالتغييرات اللازمة.	غير موجود	الضوابط العامة لتقنية المعلومات (ITGCs)
1.16	يجب تفعيل سجل التدقيق (Audit Trail) على النظام وقاعدة البيانات وتسجيل ومتابعة العمليات / الحركات التي تتم على النظام	شبه فعال	الضوابط العامة لتقنية المعلومات (ITGCs)

الرمز المرجعي	الضابط	التقييم	العملية / النشاط
1.17	إجراء اختبار تقييم الضعف والاختراق بشكل دوري (Vulnerability and Penetration Testing).	شبه فعال	الضوابط العامة لتقنية المعلومات (ITGCs)
1.18	التأكد من كفاية وفعالية عملية الاستجابة للحوادث الأمنية (السيبرانية)	شبه فعال	الضوابط العامة لتقنية المعلومات (ITGCs)
1.19	حفظ نسخ احتياطية مناسبة وتحديثها بشكل دوري على النظام المالي	فعال	الضوابط العامة لتقنية المعلومات (ITGCs)
1.20	تطبيق ضوابط الأمن المادي والبيئي على مركز البيانات	شبه فعال	الضوابط العامة لتقنية المعلومات (ITGCs)
1.21	توثيق تدفق البيانات والتصاميم المعيارية للنظام المالي للتحقق من كفاءة تصميم البنية التحتية	غير موجود	الضوابط العامة لتقنية المعلومات (ITGCs)
2.1	إغلاق الفترة المالية الشهرية وفتح فترة جديدة من قبل الموظف المفوض بحيث لا يمكن التعديل على الفترات المغلقة في النظام.	فعال	المالية والميزانية
2.2	سجل محدث بالأصول الثابتة في الجهة يشمل بحد أدنى على (الأصل، رقم (رمز) الأصل المرجعي، تاريخ الشراء، تكلفة الأصل، اسم صاحب العهدة ...) بالإضافة إلى ترميز الأصول الثابتة وجردها بشكل دوري مره في السنة على الأقل	شبه فعال	المالية والميزانية
2.3	الفصل بين المهام ذات الطبيعة المتعارضة فيما يخص إعداد واعتماد أوامر الصرف (داخليا لدى الجهة وليس على منصة اعتماد) مع وجود الموافقات الملائمة.	غير موجود	المالية والميزانية
2.4	عدم وجود صلاحية التعديل على أمر الصرف بعد اعتماده.	غير موجود	المالية والميزانية
2.5	الفصل بين المهام ذات الطبيعة المتعارضة عند تسجيل القيود المحاسبية (بما يشمل قيود الإيرادات والمصروفات) مع وجود الموافقات الملائمة.	غير موجود	المالية والميزانية
2.6	المطابقات الشهرية للحسابات وعمل التسويات اللازمة ومطابقة أرصدة الحسابات في الأستاذ العام مع الحسابات البنكية (التجارية / البنك المركزي).	غير موجود	المالية والميزانية
2.7	الالتزام بالأنظمة واللوائح فيما يخص السلف المستديمة والمؤقتة.	فعال	المالية والميزانية
2.8	سجل أعمار العهد تحت التحصيل ومتابعتها بشكل دوري وتحديد أسباب عدم تحصيلها.	شبه فعال	المالية والميزانية
2.9	وجود خطة مشتريات موثقة ومعتمدة للرفع على منصة اعتماد.	شبه فعال	المشتريات والعقود
2.10	تشكيل لجان فتح وفحص العروض تأهيل الموردين حسب الأنظمة واللوائح.	فعال	المشتريات والعقود
2.11	الالتزام بشروط تصنيف المنافسات، ووجود الموافقات الملائمة على ترسية المنافسة من اصحاب الصلاحيات	شبه فعال	المشتريات والعقود
2.12	الالتزام بشروط تصنيف الشراء المباشر، ووجود الموافقات الملائمة على التعميد (أمر الشراء المباشر) من قبل أصحاب الصلاحيات.	شبه فعال	المشتريات والعقود
2.13	وجود الموافقات الملائمة على عملية ادخال العقود في النظام، والموافقات الملائمة على أوامر التغيير للعقود.	شبه فعال	المشتريات والعقود
2.14	تسجيل ومتابعة الضمانات البنكية بشكل دوري.	فعال	المشتريات والعقود
2.15	الفصل بين المهام الخاصة بمراقبة المخزون وعمليات إدارة المستودعات ونشاط المشتريات.	شبه فعال	المستودعات ومراقبة المخزون
2.16	الفصل بين المهام عند استلام ومعاينة وتسجيل المخزون وصرفه مع وجود الموافقات الملائمة.	غير موجود	المستودعات ومراقبة المخزون



الرمز المرجعي	الضابط	التقييم	العملية / النشاط
2.17	عدم وجود صلاحية التعديل على سجلات المخزون. (Masterfile)	غير موجود	المستودعات ومراقبة المخزون
2.18	تسجيل وتكويد أصناف المخزون في المستودعات وإجراء جرد سنوي للمخزون وتشكيل لجنة الجرد.	غير موجود	المستودعات ومراقبة المخزون
2.19	وجود الموافقات على عملية الإدراج للموظفين الجدد من خلال النظام وفقاً لمصفوفة الصلاحيات وإدراج الموظفين الجدد ضمن مسير الرواتب بعد الاعتماد.	شبه فعال	الموارد البشرية
2.20	الفصل في المهام بين عملية إعداد ومراجعة واعتماد مسيرات الرواتب والمكافآت، وتقييد صلاحيات التعديل والحذف على ملفات المسيرات مع تشفيرها لتقييد صلاحية الإطلاع عليها	شبه فعال	الموارد البشرية
2.21	اسقاط أسماء الموظفين المنتهية علاقتهم بالجهة (المستقلين / متقاعدين ... إلخ) من مسيرات الرواتب.	فعال	الموارد البشرية
2.22	ملائمة الصلاحيات الممنوحة على النظام في التعديل على السلم الوظيفي والفصل بين المهام عند التعديل.	غير موجود	الموارد البشرية
2.23	دقة وصحة صرف المكافآت (السنوية / التميز / الأداء) وفقاً لما تحدده الأنظمة واللوائح أو اللائحة الإدارية للجهة في حال وجود أي استثناءات.	فعال	الموارد البشرية
2.24	اعتماد اللوائح الإدارية والسلالم الوظيفية التي تخص الجهة الحكومية من قبل الجهات المعنية.	لا ينطبق	الموارد البشرية
2.25	الالتزام بالأنظمة واللوائح فيما يخص البدلات التالية: (بدل السكن، بدل النقل، بدل التعليم) والبدلات الأخرى حسب طبيعة الجهات الحكومية.	فعال	الموارد البشرية
2.26	قرار انتداب معتمد من قبل صاحب الصلاحية وعدم تجاوز المدد النظامية للانتداب في السنة المالية	فعال	الموارد البشرية
2.27	وجود موافقات مسبقة قبل تكليف الموظف بعمل إضافي	فعال	الموارد البشرية



ثانياً: ملاحظات التقييم –
فعالية الإدارات الرقابية
والضوابط العامة لتقنية
المعلومات (ITGCs)

ثانياً: ملاحظات التقييم – فعالية الإدارات الرقابية والضوابط العامة لتقنية المعلومات (ITGCs)

شبه فعال	استقلالية نشاط المراجعة الداخلية		1.
1.1	الرمز المرجعي	المعايير العالمية للتدقيق الداخلي المبدأ 7 الموقع المستقل المعيار 7.1 الاستقلالية التنظيمية	مرجع الضابط الرقابي
		استقلالية نشاط المراجعة الداخلية في الجهة واستقلالية مدير عام المراجعة الداخلية.	ملخص الضابط الرقابي
الملاحظات			
من خلال فحص ومراجعة استقلالية نشاط المراجعة الداخلية، تبين لفريق التقييم عدم اعتماد مؤشرات قياس الأداء لمدير المراجعة الداخلية. وذلك بسبب الاجراء الراهن حيث يُربط تقييم مدير إدارة المراجعة الداخلية بتقييم إدارة المراجعة.			
الأثر / الخطر المصاحب			
- احتمالية التأثير سلباً على موضوعية أو استقلالية نشاط المراجعة الداخلية مما قد يؤدي إلى ضعف في نتائج المراجعة. - احتمالية عدم وضع الضمانات الكافية على الأدوار التنفيذية التي قد يؤديها مدير المراجعة الداخلية.			
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة	
30 - سبتمبر - 2026م	إدارة المراجعة الداخلية	العمل على اعتماد مؤشرات قياس الاداء لمدير المراجعة الداخلية.	



شبه فعال	خطة المراجعة الداخلية		2.
1.2	الرمز المرجعي	المعايير العالمية للتدقيق الداخلي المبدأ 9 التخطيط الاستراتيجي المعيار 9.4 خطة التدقيق الداخلي	مرجع الضابط الرقابي
		خطة سنوية للمراجعة الداخلية على مستوى استراتيجي أو تشغيلي بناء على نتائج تقييم المخاطر تشمل: العمليات التالية (المالية والميزانية، المشتريات والعقود، المستودعات ومراقبة المخزون، الموارد البشرية، تقنية وأمن المعلومات).	ملخص الضابط الرقابي
الملاحظات			
من خلال فحص ومراجعة خطة المراجعة الداخلية، تبين لفريق التقييم أن الخطة لا تغطي أنشطة المستودعات ومراقبة المخزون والموارد البشرية والأمن السيبراني. وذلك بسبب عدم وجود الموارد الكافية لتغطية الأنشطة المطلوبة.			
الأثر / الخطر المصاحب			
- احتمالية عدم مراعاة المخاطر التي تواجهها الجهة عند تحديد أولويات عمليات المراجعة. - احتمالية عدم القدرة على تقييم نظام الرقابة الداخلية في الجهة بشكل فعال نتيجة حدوث أي تغييرات في مخاطر وعمليات وأنظمة الجهة.			
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة	
30 - يونيو - 2027م	إدارة المراجعة الداخلية	العمل على تغطية الخطة السنوية للمراجعة الداخلية للأنشطة التالية: - المستودعات ومراقبة المخزون - الموارد البشرية - الأنظمة المالية التقنية	





3.		الإجراءات المتعلقة بالعمليات الخاضعة للرقابة المالية.		غير موجود
مرجع الضابط الرقابي		إطار الرقابة الداخلية COSO / الأنشطة الرقابية / السياسات والإجراءات.		الرمز المرجعي
ملخص الضابط الرقابي		توثيق الإجراءات والصلاحيات المرتبطة بالعمليات الخاضعة للرقابة المالية.		
الملاحظات				
من خلال فحص ومراجعة الإجراءات والصلاحيات المرتبطة بالعمليات الخاضعة للرقابة المالية، تبين لفريق التقييم عدم وجود أدلة سياسات وإجراءات لإدارات المالية والميزانية والموارد البشرية والمشتريات والعقود والمستودعات ومراقبة المخزون بالإضافة الى عدم وجود منهجية موثقة وموحدة لدى المجلس توضح آليات توثيق أدلة الإجراءات الخاصة بالإدارات أو الأقسام الداخلية، وذلك بسبب عدم وجود إجراء موثق ومعتمد.				
الأثر / الخطر المصاحب				
- احتمالية عدم قدرة الإدارات على اتمام مهامها وأعمالها بالفاعلية والكفاءة المطلوبة. - احتمالية عدم مواءمة السياسات والإجراءات مع الأهداف الاستراتيجية للقطاعات والإدارات. - احتمالية ازدواجية الأدوار والمسؤوليات بين الإدارات فى الجهة.				
خطة عمل الإدارة		المسؤول عن التنفيذ		تاريخ التنفيذ
العمل على التالى:		إدارة التميز المؤسسي		30 – يونيو -2027م
- أدلة سياسات وإجراءات لإدارات المالية والميزانية والموارد البشرية والمشتريات والعقود والمستودعات ومراقبة المخزون وتوثيقها واعتمادها من قبل صاحب الصلاحية - منهجية موثقة وموحدة لدى المجلس توضح آليات توثيق أدلة الإجراءات الخاصة بالإدارات أو الأقسام الداخلية.				



شبه فعال	تقييم المخاطر		4.
1.6	الرمز المرجعي	آيزو 31000 / إطار إدارة المخاطر / التنفيذ إطار COSO-ERM لإدارة المخاطر على مستوى المؤسسة / الأداء.	مرجع الضابط الرقابي
		تقييم المخاطر المرتبطة بالعمليات التالية (المالية والميزانية، المشتريات والعقود، المستودعات ومراقبة المخزون، الموارد البشرية، تقنية وأمن المعلومات) بشكل دوري وتحديد وتوثيق خطط معالجة تلك المخاطر مع الإدارات المعنية	ملخص الضابط الرقابي
الملاحظات			
من خلال فحص ومراجعة سجلات المخاطر، تبين لفريق التقييم عدم تحديث السجلات بالإضافة إلى عدم شمولية السجل لبعض العناصر على سبيل المثال لا الحصر (آثار المخاطر، تقييم الخطر الكامن، الضوابط المطبقة لتقليل الأثر واحتمالية حدوث الخطر، تقييم فعالية الضوابط المطبقة، تقييم الخطر المتبقى، خطط الحد من المخاطر، تاريخ انتهاء تنفيذ خطط المعالجة للخطر)، كما أن بعض سجلات الإدارات غير مكتملة العناصر كسجل مخاطر إدارتي الأمن السيبراني والمشتريات. وذلك بسبب عدم وجود تحديث ومراجعة دورية للسجل.			
الأثر / الخطر المصاحب			
- احتمالية عدم الاستجابة بشكل فعال للمخاطر في حال حدوثها. - احتمالية ضعف جودة نتائج أعمال المخاطر وعدم مواكبتها لأفضل الممارسات.			
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة	
30 - يونيو - 2027م	وحدة إدارة المخاطر واستمرارية الأعمال	العمل على التالي: - تحديث السجلات دورياً. - شمولية السجل لبعض العناصر على سبيل المثال لا الحصر (آثار المخاطر، تقييم الخطر الكامن، الضوابط المطبقة لتقليل الأثر واحتمالية حدوث الخطر، تقييم فعالية الضوابط المطبقة، تقييم الخطر المتبقى، خطط الحد من المخاطر، تاريخ انتهاء تنفيذ خطط المعالجة للخطر). - اكتمال عناصر جميع سجلات المخاطر لجميع الإدارات.	



شبه فعال	قنوات استلام البلاغات		5.
1.7	الرمز المرجعي	ايزو 37302 / نظام إدارة الإبلاغ عن الفساد / المخالفات.	مرجع الضابط الرقابي
		قنوات خاصة باستلام البلاغات عن حالات الاحتيال والفساد والمخالفات المالية وفرزها وإدارتها.	ملخص الضابط الرقابي
الملاحظات			
من خلال فحص ومراجعة القنوات الخاصة باستلام البلاغات، تبين لفريق التقييم عدم وجود سجل معتمد يحتوي على كافة البلاغات المرصودة وحالة كل بلاغ. وذلك بسبب حداثة إجراءات استلام وإنشاء قنوات خاصة بالبلاغات.			
الأثر / الخطر المصاحب			
- احتمالية غياب التواصل الفعال بين إدارة الالتزام والإدارة العليا. - احتمالية عدم قدرة الإدارة العليا على اتخاذ القرارات المناسبة نتيجة غياب التواصل الفعال من قبل إدارة الالتزام. - تعرض الجهة لمخاطر مخالفة الأنظمة واللوائح / المخالفات الأخرى نتيجة عدم معالجة البلاغات في الوقت المناسب أو عدم وجود قنوات خاصة باستلام البلاغات.			
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة	
30 - يونيو - 2027م	إدارة الالتزام	العمل على وجود سجل للبلاغات موثق ومعتمد.	





شبه فعال	حوكمة العمليات التقنية		6.
1.8	الرمز المرجعي	الضوابط الأساسية للأمن السيبراني: ضابط 1.1.1-ECC: "يجب على الجهة تطوير واعتماد سياسات للأمن السيبراني لتغطية نطاق عملها، بما يتماشى مع الاستراتيجية الوطنية للأمن السيبراني والأنظمة واللوائح وأفضل الممارسات الدولية." COBIT 2019 ضابط APO01.01: يجب تحديد السياسات والإجراءات والمعايير التي تدعم تنفيذ أهداف الحوكمة والإدارة. ينبغي أن تكون هذه الوثائق متوافقة مع المتطلبات المؤسسية والتشريعية والتنظيمية لضمان وجود توجيه موحد ومتسق لكيفية تنفيذ الأنشطة التقنية والمعلوماتية بما يتوافق مع أهداف المؤسسة.	مرجع الضابط الرقابي
		تطوير سياسات وإجراءات موثقة ومعتمدة وشاملة لجميع العمليات التقنية في الجهة الحكومية ذكر السياسات المطلوبة ضمن خطوات الفحص	ملخص الضابط الرقابي
الملاحظات			
من خلال مراجعة فريق التقييم للعمليات المتبعة في إدارة حوكمة تقنية المعلومات، تبين عدم وجود مصفوفة صلاحيات معتمدة لكل من نظام المالية، ونظام المستودعات، ونظام المشتريات، ونظام الموارد البشرية تُحدّد بشكل واضح الأدوار الوظيفية المختلفة، ومستويات الصلاحيات المرتبطة بكل دور، ونطاق العمليات المسموح بتنفيذها لكل فئة من المستخدمين، بما يضمن التحكم المناسب في صلاحيات المستخدمين، وذلك بسبب عدم تحديث المسميات الوظيفية ليعكسها على مصفوفة الصلاحيات.			
الأثر / الخطر المصاحب			
- غياب سياسات وإجراءات واضحة وشاملة قد يؤدي إلى عدم وضوح طرق تنفيذ العمليات وعدم الامتثال للمعايير الوطنية والعالمية المتبعة، مما يزيد من احتمالية حدوث الأخطاء والتجاوزات. - عدم وجود مصفوفة صلاحيات معتمدة أو عدم تطبيقها فعلياً على الأنظمة قد يؤدي إلى منح صلاحيات غير مناسبة لمستخدمين، مما يفتح المجال للقيام بعمليات غير مصرح بها. - غياب فصل المهام يسمح للمستخدم بتنفيذ العملية دون رقابة مستقلة، مما يزيد من مخاطر التلاعب أو الأخطاء غير المكتشفة، ويؤثر سلباً على فعالية الرقابة الداخلية ومصادقية البيانات.			
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة	
30 - يونيو - 2027م	إدارة تقنية المعلومات	العمل على إعداد واعتماد مصفوفات صلاحيات (Access Control Matrix) لجميع الأنظمة المستهدفة، تتضمن تحديد الأدوار الوظيفية، ومستويات الصلاحيات، ونطاق العمليات لكل دور، وتحديد الأدوار المتعارضة والضوابط المانعة لتداخل الصلاحيات، بما يتوافق مع المهام الفعلية ومبدأ الحد الأدنى من الصلاحيات.	

شبه فعال	انشاء حسابات المستخدم	7.
1.9	المعهد الوطني للمعايير والتقنية (NIST-171-800): - ضابط (AC-1): تطوير وتوثيق واعتماد ومراجعة سياسة إدارة الوصول بشكل دوري ومشاركتها مع أصحاب المصلحة. - ضابط (AC-2): منح وتفعيل وتعديل وتعطيل وإزالة الصلاحيات بناءً على سياسة وإجراءات الجهة. - ضابط ((AC-3(3): "المنشأة تحدد الامتيازات التي يمكن منحها للمستخدمين وكيفية منحها". الضوابط الأساسية للأمن السبراني: ضابط (2-3-3): يجب أن تغطي متطلبات الأمن السبراني المتعلقة بإدارة هويات الدخول والصلاحيات في الجهة إدارة تصاريح وصلاحيات المستخدمين (Authorization) بناءً على مبادئ التحكم بالدخول والصلاحيات (مبدأ الحاجة إلى المعرفة والاستخدام "Need-to-know and Need-to-use" ومبدأ الحد الأدنى من الصلاحيات والامتيازات "Privilege Least"، ومبدأ فصل المهام "Segregation of Duties")	مرجع الضابط الرقابي
	أخذ الموافقات اللازمة على إنشاء حساب مستخدم جديد أو تعديل صلاحيات حساب مستخدم موجود على النظام المالي، حسب مصفوفة الصلاحيات المعتمدة	ملخص الضابط الرقابي
الملاحظات		
من خلال مراجعة فريق التقييم للعمليات المتبعة في إدارة صلاحيات وصول المستخدمين، تبين ما يلي: - عدم وجود إجراء معتمد وموثق لموافقات طلب واعتماد إنشاء الحسابات. حيث لم يمكن التحقق من توفر الموافقات اللازمة قبل إنشاء الحسابات لعدد (5) عينات من أصل (15) مستخدماً - عدم وجود سجل يوثق التعديل على الصلاحيات، لأنظمة (المستودعات، والمشتريات، والموارد البشرية) - عدم وجود إجراء معتمد وموثق للموافقات اللازمة عند التعديل على الصلاحيات، لأنظمة (المستودعات، المشتريات، الموارد البشرية والنظام المالي). وذلك بسبب غياب الإجراءات لإدارة واعتماد وتتبع طلبات إنشاء وتعديل صلاحيات وصول المستخدمين.		
الأثر / الخطر المصاحب		
- إمكانية الوصول غير المصرح به أو المفرط والحصول على صلاحيات غير مخولة على التطبيقات الرئيسية. - الوصول غير المناسب إلى أنظمة وبيانات التطبيق بسبب عملية إدارة الوصول غير الفعالة قد تؤدي إلى فرص التعديل (غير المتعمد) أو إساءة استخدام أصول الجهة، وتسريب المعلومات السرية والحساسة.		
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة

30 - يونيو - 2027م	إدارة تقنية المعلومات	العمل على التالي: - اجراء معتمد وموثق للموافقات اللازمة لطلب واعتماد إنشاء وتعديل وإلغاء الحسابات - سجل يوثق التعديل على الصلاحيات، لأنظمة (المستودعات، والمشتريات، والموارد البشرية) - اجراء معتمد وموثق للموافقات اللازمة عند التعديل على الصلاحيات، لأنظمة (المستودعات، المشتريات، الموارد البشرية والنظام المالي) .
--------------------	-----------------------	--

غير موجود	صلاحيات الوصول الى النظام		8.
1.11	الرمز المرجعي	المعهد الوطني للمعايير والتقنية (NIST-171-800): ضابط (AC-3(3)): "المنشأة تحدد الامتيازات التي يمكن منحها للمستخدمين وكيفية منحها". الضوابط الأساسية للأمن السيبراني: ضابط (2-3-3): يجب أن تغطي متطلبات الأمن السيبراني المتعلقة بإدارة هويات الدخول والصلاحيات في الجهة إدارة الصلاحيات الهامة والحساسة (Privileged Management Access).	مرجع الضابط الرقابي
		أخذ الموافقات اللازمة على إعطاء صلاحيات "مشرف" وصلاحيات مميزة للوصول إلى النظام المالي وقواعد بيانات النظام لعدد محدود من المستخدمين حسب مصفوفة الصلاحيات المعتمدة	ملخص الضابط الرقابي
الملاحظات			
من خلال مراجعة فريق التقييم للعمليات المتبعة في إدارة هويات الدخول والصلاحيات، تبين ما يلي: • عدم توفر سجل معتمد ومحدث لحصر ومتابعة الحسابات ذات الصلاحيات المميزة الخاصة بموظفي إدارة تقنية المعلومات (IT and Database Administrators)، الأمر الذي حد من قدرة فريق التقييم على التحقق من وجود الموافقات اللازمة لمنح هذه الصلاحيات. • وجود حساب واحد ذو صلاحيات مميزة على قاعدة البيانات، دون توفر موافقات رسمية أو توثيق معتمد من الجهات المخولة يثبت منح هذه الصلاحيات • وجود عدد (5) مستخدمين يمتلكون صلاحيات المشرف على النظام، لموظفين من خارج إدارة تقنية المعلومات، بما يمكنهم من منح أو تعديل صلاحيات المستخدمين التابعين لإداراتهم، كما تبين عدم توفر موافقات رسمية ومعتمدة على منح هذه الصلاحيات وذلك بسبب غياب إطار حوكمة فعال يُنظم عملية منح وتعديل واعتماد الصلاحيات المميزة على النظام وقاعدة البيانات.			
الأثر / الخطر المصاحب			
• الوصول غير المصرح به أو المفرط والحصول على صلاحيات غير مخولة على التطبيقات الرئيسية. • أنشطة غير مصرح بها أو ضارة على النظام. وهذا يشكل بسبب منح امتياز قاعدة البيانات/وصول المسؤول للمستخدمين غير المناسبين مما قد يؤدي إلى مخاطر قد تؤثر سلباً على سلامة وسرية وأمن المعلومات في النظام.			
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة	
30 - يونيو - 2027م	إدارة تقنية المعلومات	العمل على التالي: • الالتزام بتوثيق جميع الموافقات الخاصة بإنشاء وتعديل الحسابات المميزة على كل الأنظمة أو قاعدة البيانات من خلال نظام مركزي معتمد، يوفر إمكانيات تتبع وأرشفة كاملة لطلبات الوصول (إنشاء	

		– تعديل)، مع تفعيل واعتماد سلسلة موافقات رسمية داخل النظام بشكل موحد. مراجعة صلاحيات المشرف الممنوحة حاليًا للمستخدمين من غير منسوبي إدارة تقنية المعلومات، وإلغاء الصلاحيات غير المبررة. كما يتم قصر صلاحيات منح وتعديل وإزالة صلاحيات المستخدمين على إدارة تقنية المعلومات فقط، مع تطبيق مبدأ الفصل بين المهام (Segregation of Duties) لضمان عدم تعارض الصلاحيات.
--	--	--

9.	صلاحيات المستخدمين والوصول الى النظام	غير موجود
مرجع الضابط الرقابي	المعهد الوطنى للمعايير والتقنية (NIST-171-800): ضابط (AC-6(7)) تحديد المستخدمين الذين تم تعيين الامتيازات لهم وتحديد مدى تكرار مراجعة الامتيازات المخصصة للأدوار المحددة من قبل المنشأة للتحقق من الحاجة إلى هذه الامتيازات ومن ثم إعادة تعيين الامتيازات أو إلزالتها، إذا لزم الأمر، لتعكس المهام التنظيمية / احتياجات العمل بشكل صحيح. الضوابط الأساسية للأمن السيبراني: - ضابط (2-3-3): يجب أن تغطي متطلبات الأمن السيبراني المتعلقة بإدارة هويات الدخول والصلاحيات فى الجهة المراجعة الدورية لهويات الدخول والصلاحيات.	1.12
ملخص الضابط الرقابي	تتم المراجعة على صلاحيات المستخدمين وصلاحيات الوصول periodic user review على النظام بشكل دوري.	
الملاحظات		
من خلال مراجعة فريق التقييم للعمليات المتبعة فى إدارة هويات الدخول والصلاحيات، تبين ما يلى: - عدم تنفيذ مراجعات دورية ومنهجية لصلاحيات وصول المستخدمين (العادية والمميّزة) على الأنظمة، بما يضمن توافق الصلاحيات الممنوحة مع مصفوفة الصلاحيات واستمرارية ملائمتها لطبيعة المهام الوظيفية. - وجود عدد (149) حساباً مميزاً عامّاً (Generic Accounts)، وعدد (61) مستخدماً لا يتوفر لهم تاريخ آخر تسجيل دخول حيث تظهر القيمة (0) فى خانة آخر دخول، وعدد (183) مستخدم لم يسجلوا دخولاً منذ أكثر من 60 يوم رغم بقاء حساباتهم مفعّلة، وعدد (226) مستخدماً لم يتم تغيير كلمات المرور الخاصة بهم منذ أكثر من 180 يوم وذلك من أصل عدد (489) حساباً. - عدم وجود فصل واضح للمهام بين الموظفين على مستوى أنظمة (المالية، والمستودعات، والمشتريات، والموارد البشرية)، حيث يمتلك بعض المستخدمين صلاحيات متداخلة تتيح لهم تقديم الطلب دون المرور بسلسلة موافقات معتمدة، وهو ما لا يتوافق مع مبدأ الفصل بين المهام (Segregation of Duties). وذلك بسبب عدم وجود إجراءات معتمدة لإدارة ومراجعة صلاحيات المستخدمين والحسابات الخاملة.		
الأثر / الخطر المصاحب		
غياب المراجعة الرسمية الدورية لحقوق وصول المستخدم من قبل اصحاب الصلاحيات قد يؤدي إلى منح المستخدمين صلاحيات وصول مفرطة وغير مصرحة للأنظمة مما يسبب زيادة احتمالية تعديل البيانات فى النظام بطريقة غير صحيحة وتنفيذ بعض العمليات الغير مصرح بها		



- عدم الفصل فى الواجبات والوصول المفرد أو الوصول غير المصرح به إلى بيانات ومعلومات ووظائف التطبيق بسبب عدم مراجعة حقوق وصول المستخدم مما قد يؤدي إلى زيادة مخاطر الانتهاكات الأمنية.

تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة
30 - يونيو - 2027 م	إدارة الأمن السيبراني	العمل على التالي: • إجراء مراجعة دورية لصلاحيات الوصول على الأنظمة وفقًا لمصفوفة الصلاحيات المعتمدة، وإعادة موافقة صلاحيات المستخدمين بما يتوافق مع مهامهم الوظيفية. مع توثيق نتائج المراجعة بشكل رسمي واعتمادها من قبل الجهات وأصحاب الصلاحيات المعنيين. • تنفيذ مراجعة شاملة لحسابات المستخدمين لمعالجة الحسابات العامة، وتعطيل الحسابات غير النشطة، وتحديث كلمات المرور، مع تقليل استخدام الحسابات العامة وتحديد الغرض منها وتعيين مسؤولية واضحة لكل حساب، مع توثيق نتائج المراجعة بشكل رسمي واعتمادها من قبل الجهات وأصحاب الصلاحيات المعنيين



غير موجود	تسجيل وتصنيف التغييرات المنفذة على النظام المالي	10.
1.14	ITIL: ضابط 4.2.5: يتم تسجيل وتصنيف جميع التغييرات حسب آلية تحددها الجهة ويفضل أن تكون عن طريق نظام لتخزين جميع بيانات ووثائق التغيير. - ضابط 4.4.5: إشراك مستخدمي النظام الرئيسيين في التطوير وإجراء اختبار قبول المستخدم. - ضابط 4.5.4.10: تقييم ما إذا كان التغيير جذري ويستوجب تحديث خطة التعافي من الكوارث بناءً على التغيير بالإضافة إلى تقييم ما إذا كان ذلك التغيير يستوجب اختباره حسب خطة التعافي من الكوارث المحدثة وتوثيق النتائج بالمواءمة مع فريق استمرارية الأعمال. - ضابط 4.4.5.1: الذي يحدّد على اختبار قبول المستخدم للتغييرات على النظام. - ضابط 4.2.5.5: وجوب تحديد خطر التغيير عن طريق تحليل تأثير على الأعمال للتغييرات.	مرجع الضابط الرقابي
	تسجيل وتصنيف التغييرات المنفذة على النظام المالي بعد أخذ الموافقات اللازمة والتواؤم مع المجلس الاستشاري للتغيير (CAB) وإجراء اختبارات الجودة اللازمة.	ملخص الضابط الرقابي
الملاحظات		
من خلال مراجعة فريق التقييم للعمليات المتبعة لإدارة التغييرات تبين، ما يلي: • عدم وجود قائمة التغييرات على النظام خلال فترة التقييم وبالتالي لم يتمكن من فحص ما يلي: - طلب التغيير - موافقة أصحاب المصلحة. - تحليل الأثر على الأعمال. - تحليل الأثر على الأمن السيبراني. - خطة الاختبار. - حالات الاختبار - نتائج الاختبار وتوثيقها. - خطة التراجع (Rollback Plan). - اختبار قبول المستخدم (UAT). • عدم وجود لجنة استشارية للتغيير مسؤولة عن مراجعة وتقييم طلبات التغيير في الأنظمة التقنية. • تغييرات النظام المالي تُنفذ مباشرة مع مزود الخدمة (أزكى) بالتنسيق مع إدارة المالية فقط، دون إشراك إدارة تقنية المعلومات في هذه العملية أو تحديد دور واضح لها في مراجعة واعتماد التغييرات. وذلك بسبب غياب إطار معتمد لإدارة التغيير يحدّد الإجراءات، الأدوار، وآليات المراجعة والاعتماد والتوثيق.		
الأثر / الخطر المصاحب		
• في حال عدم تطبيق ضوابط فعالة لإدارة التغيير، قد يتم تنفيذ تغييرات على الأنظمة دون مراجعة أو موافقة مناسبة، مما يزيد من مخاطر التسبب في أعطال بالنظام، أو ضعف في الأداء، أو إدخال ثغرات أمنية. • غياب التوثيق والتحقق من الاختبارات وخطط التراجع قد يؤدي إلى صعوبة تحديد أسباب المشاكل أو التراجع عنها في الوقت المناسب، مما يؤثر سلباً على استمرارية الأعمال وأمن المعلومات. • غياب لجنة التغيير قد يؤدي إلى تنفيذ تغييرات دون تقييم شامل لتأثيرها على الأعمال أو الأمن السيبراني، مما قد يؤدي إلى أعطال في الأنظمة أو إدخال ثغرات أمنية أو فقدان بيانات.		



- غياب التوثيق الرسمي وآليات الحوكمة لاجتماعات اللجنة يضعف من مستوى التنسيق والشفافية فى اتخاذ قرارات التغيير، ويؤثر سلباً على فعالية الرقابة والمساءلة بين أصحاب المصلحة.

تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة
30 - يونيو - 2027م	إدارة تقنية المعلومات	العمل على التالى: • إعداد وتطبيق آلية موحدة ومعتمدة لإدارة التغييرات التقنية، تضمن توثيق جميع مراحل التغيير بشكل مركزي، بما يشمل طلب التغيير، وموافقات أصحاب الصلاحية المعنيين، وتحليل الأثر على الأعمال، وتحليل الأثر على الأمن السيبراني، وخطط الاختبار وحالات الاختبار ونتائجها، إضافة إلى توثيق خطة التراجع (Rollback Plan) واختبار قبول المستخدم (User Acceptance Test – UAT). • تشكيل لجنة استشارية للتغيير (Change Advisory Board – CAB) تكون مسؤولة عن مراجعة واعتماد التغييرات التقنية قبل تنفيذها، بما يضمن خضوع جميع التغييرات لرقابة مستقلة ومنهجية. • إعداد ميثاق رسمي للجنة التغيير يوضح الأدوار والمسؤوليات، وآلية اتخاذ القرار، وصلاحيات الاعتماد، بما يضمن وضوح الحوكمة والمسؤوليات المرتبطة بإدارة التغيير. • توثيق محاضر اجتماعات لجنة التغيير بشكل دوري، وحفظها فى مستودع مركزي معتمد، بما يتيح الرجوع إليها عند الحاجة ويدعم قابلية التتبع والمراجعة. • ضرورة قيام إدارة تقنية المعلومات بمراقبة واعتماد جميع إجراءات التغيير والإنتاج الخاصة بالنظام المالى.



غير موجود	تسجيل وتصنيف التغييرات المنفذة على النظام المالي	11.
1.15	الرمز المرجعي	ITIL: ضابط 4.4.5: وجوب الفصل بين البيئات والتأكد من اختبار التغيير على بيئة الاختبار قبل الانتقال الى بيئة الإنتاج. -ضابط 5.4.4: يجب أن تكون البيئات آمنة لضمان عدم وجود وصول غير مصرح به وأن الفصل بين البيئات إجباري.
		توفر بيئات التطوير والاختبار والإنتاج (Development, testing and Production) وتوزيع المهام وفصلها على المستخدمين المصرح لهم إجراء التغييرات في البيئات المختلفة بحيث يكون لكل بيئة مستخدمين مخولين بالقيام بالتغييرات اللازمة.
الملاحظات		
من خلال مراجعة فريق التقييم للعمليات المتبعة لإدارة التغيير، تبين ما يلي: - وجود بيئتين فقط للأنظمة، وهما بيئة الإنتاج (PROD) وبيئة الاختبار (UAT)، دون وجود بيئة تطوير (Development) مخصصة. - عدم تطبيق مبدأ الفصل بين المهام (Segregation of Duties) بشكل فعال على بيئات أنظمة (المستودعات، والمشتريات، والموارد البشرية)، حيث يمتلك جميع المستخدمين صلاحيات وصول متزامنة إلى أكثر من بيئة تشغيلية، بما في ذلك بيئات الاختبار والإنتاج. وذلك بسبب قصور في الضوابط المطبقة للتحكم في صلاحيات الوصول وتقييدها وفقاً لطبيعة كل بيئة تشغيلية ومتطلبات إدارة التغييرات.		
الأثر / الخطر المصاحب		
- عدم وجود بيئات منفصلة قد يؤدي إلى نشر تغييرات غير مصرح بها في بيئة الإنتاج. - انقطاع إجراءات العمل في الجهة بسبب نشر التغييرات غير المصرح بها في بيئة الإنتاج الخاصة بالتطبيق والتي قد تؤدي إلى تسبب مشاكل تتعلق بالنزاهة بسبب أخطاء في التغيير وإجراءات النشر الخاصة به. - عدم وجود فصل بين المهام وتوزيعها يؤدي إلى زيادة نسبة الخطأ على بيئة الإنتاج مما قد يؤدي إلى انقطاع الأعمال.		
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة
30 - يونيو - 2027م	إدارة تقنية المعلومات	العمل على التالي: - توفير ثلاث بيئات (بيئة التطوير، بيئة الاختبار، وبيئة الإنتاج). - مراجعة صلاحيات الوصول الحالية للمستخدمين الذين يمتلكون صلاحيات متزامنة على أكثر من بيئة تشغيلية (الاختبار والإنتاج) على مستوى أنظمة (المستودعات، والمشتريات، والموارد البشرية)، وإعادة مواءمة الصلاحيات بما يضمن الفصل الكامل للمهام بين البيئات الثلاث وفقاً لمبدأ الفصل بين المهام (Segregation of Duties) والضوابط المعتمدة. وفي حال وجود متطلبات تشغيلية تستدعي استثناءات على هذا المبدأ، يتم توثيق هذه الاستثناءات رسمياً والحصول على موافقات معتمدة من أصحاب الصلاحيات المعنيين، مع تحديد مبررات الاستثناء ونطاقه ومدته الزمنية، ومراجعتها بشكل دوري للتحقق من استمرار الحاجة إليه

شبه فعال	سجل التدقيق (Audit Trail) على النظام		12.
1.16	الرمز المرجعي	الضوابط الأساسية للأمن السيبراني: - ضابط (2-12-3): يجب أن تغطي متطلبات إدارة سجلات الأحداث ومراقبة الأمن السيبراني بحد أدنى تفعيل سجلات الأحداث (logs Event) الخاصة بالأمن السيبراني على الأصول المعلوماتية الحساسة لدى الجهة والحسابات ذات الصلاحيات الهامة والحساسة على الأصول المعلوماتية وأحداث عمليات الدخول عن بعد لدى الجهة.	مرجع الضابط الرقابي
		يجب تفعيل سجل التدقيق (Audit Trail) على النظام وقاعدة البيانات وتسجيل ومتابعة العمليات / الحركات التي تتم على النظام	ملخص الضابط الرقابي
الملاحظات			
من خلال مراجعة فريق التقييم للعمليات المتبعة في إدارة أمن المعلومات، تبين ما يلي: - لم يتم تفعيل سجلات التدقيق (Audit Logs) على مستوى الأنظمة الخاصة بكل من (النظام المالي، المستودعات، المشتريات، والموارد البشرية). - عدم وجود حالات استخدام (Use Cases) مفعلة لمراقبة ورصد التغييرات على مستوى هذه الأنظمة وقواعد بياناتها. - عدم وجود مراجعة دورية لسجلات التدقيق على كلا المستويين: التطبيق وقاعدة البيانات. وذلك بسبب غياب إطار حوكمة وإدارة سجلات التدقيق والمراقبة الأمنية للأنظمة (المالية، والمستودعات، والمشتريات، والموارد البشرية).			
الأثر / الخطر المصاحب			
غياب تفعيل ومراقبة سجلات التدقيق على مستوى قاعدة البيانات والتطبيق يزيد من مخاطر عدم اكتشاف الأنشطة غير المصرح بها أو الخبيثة، سواء من قبل الأنظمة أو من قبل الموظفين المختصين.			
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة	
31 - ديسمبر - 2026م	إدارة الأمن السيبراني	العمل على التالي: - تفعيل سجلات التدقيق على مستوى الأنظمة وقواعد البيانات الخاصة بكل من أنظمة (المالية، والمستودعات، والمشتريات، والموارد البشرية)، وذلك لتوثيق الأنشطة الحساسة مثل عمليات الدخول، التعديلات. - ربط سجلات التدقيق على مستوى الأنظمة وقواعد البيانات الخاصة بكل من أنظمة (المالية، والمستودعات، والمشتريات، والموارد البشرية) بنظام إدارة معلومات الأمن والأحداث (SIEM) لتحليلها مركزياً واكتشاف الأنشطة غير الاعتيادية بشكل تلقائي. - تفعيل وتطوير حالات استخدام (Use Cases) لمراقبة ورصد التغييرات على مستوى الأنظمة وقواعد البيانات الخاصة بكل من أنظمة (المالية، والمستودعات، والمشتريات، والموارد البشرية)، من خلال إعداد سيناريوهات كشف محددة للتغيرات الحساسة، مع تحديد آليات التنبيه والتصعيد، وتوثيقها واعتمادها، وضمان مراجعتها وتحديثها بشكل دوري.	

شبه فعال	تقييم الضعف والاختراق		13.
1.17	الرمز المرجعي	الضوابط الأساسية للأمن السيبراني: - ضابط 2-10-3: يجب أن تغطي متطلبات الأمن السيبراني لإدارة الثغرات بحد أدنى فحص واكتشاف الثغرات دورياً وتصنيف الثغرات حسب خطورتها ومعالجة الثغرات بناء على تصنيفها والمخاطر السيبرانية المترتبة عليها - ضابط 2-11-3: يجب أن تغطي متطلبات الأمن السيبراني لاختبار الاختراق بحد أدنى نطاق عمل اختبار الاختراق، ليشمل جميع الخدمات المقدمة خارجياً (عن طريق الانترنت) ومكوناتها التقنية، ومنها: البنية التحتية، المواقع الإلكترونية، تطبيقات الويب، تطبيقات الهواتف الذكية واللوحية، البريد الإلكتروني والدخول عن بعد.	مرجع الضابط الرقابي
		إجراء اختبار تقييم الضعف والاختراق بشكل دوري (Vulnerability and Penetration Testing).	ملخص الضابط الرقابي
الملاحظات			
من خلال مراجعة فريق التقييم للعمليات المتبعة في إدارة أمن المعلومات، تبين ما يلي: • عدم تنفيذ اختبار اختراق (Penetration Testing) وفحص ثغرات (Vulnerability Scanning) على مستوى أنظمة (المالية، والمستودعات، والمشتريات) حتى تاريخه. • تم إجراء فحص للثغرات الأمنية على نظام الموارد البشرية، حيث تم رصد عدد (3) ثغرات أمنية، تم إغلاق ثغرة واحدة فقط منها، في حين لا تزال ثغرتان قيد المعالجة حتى تاريخه، وذلك منذ فترة طويلة، مما يشير إلى عدم إغلاق الثغرات المكتشفة بشكل كامل. وذلك بسبب ضعف حوكمة إدارة الثغرات الأمنية.			
الأثر / الخطر المصاحب			
• غياب تنفيذ اختبار الاختراق والفحص الضعفي بشكل منتظم قد يؤدي إلى بقاء ثغرات أمنية غير مكتشفة في الأنظمة، مما يتيح للمهاجمين استغلالها لتنفيذ هجمات إلكترونية قد تهدد سرية وسلامة وتوافر البيانات. • غياب الالتزام بمعالجة الثغرات الأمنية ضمن الإطار الزمني المحدد في SLA قد يؤدي إلى بقاء نقاط ضعف معروفة دون معالجة لفترة طويلة، مما يزيد من احتمالية استغلالها من قبل مهاجمين، ويعرض الأنظمة والبيانات لمخاطر الاختراق أو التعطيل. • غياب إعادة اختبار الاختراق بعد معالجة الثغرات قد يؤدي إلى بقاء بعض الثغرات دون تأكيد فعاليتها معالجتها، مما يزيد من احتمال استغلالها لاحقاً، ويقلل من موثوقية إجراءات التصحيح، ويؤثر على مستوى الأمان العام للأنظمة.			
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة	
31 - ديسمبر - 2026م	إدارة الأمن السيبراني	العمل على التالي: • إجراء تقييم الضعف (Vulnerability Assessment) على مستوى أنظمة (المالية، والمستودعات، والمشتريات، والموارد البشرية)، وذلك باستخدام أدوات متخصصة. • معالجة الثغرات المكتشفة من تقييم الضعف (Vulnerability Assessment) وفقاً لاتفاقية مستوى الخدمة وبناءً على درجة خطورتها. • إجراء اختبار اختراق (Penetration Testing) على مستوى أنظمة (المالية، والمستودعات، والمشتريات، والموارد البشرية).	



		تنفيذ إعادة اختبار (Re-test) للثغرات الناتجة من اختبار الاختراق (Penetration Testing)، وتقييم الضعف (Vulnerability Assessment) للتأكد من إغلاقها بشكل كامل.
--	--	---

شبه فعال	الاستجابة للحوادث الأمنية (السيبرانية)		14.
1.18	الرمز المرجعي	الضوابط الأساسية للأمن السيبراني: - ضابط 2-3-12: يجب أن تغطي متطلبات إدارة حوادث وتهديدات الأمن السيبراني بحد أدنى ما يلي: 1-3-13 وضع خطط الاستجابة للحوادث الأمنية وآليات التصعيد. 2-13-3-2 تصنيف حوادث الأمن السيبراني. 3-13-3-2 تبليغ الهيئة عند حدوث حادثة أمن سيبراني. 4-13-3-2 مشاركة التنبيهات والمعلومات الاستباقية ومؤشرات الاختراق وتقارير حوادث الأمن السيبراني مع الهيئة. 5-13-3-2 الحصول على المعلومات الاستباقية والتعامل معها.	مرجع الضابط الرقابي
		التأكد من كفاية وفعالية عملية الاستجابة للحوادث الأمنية (السيبرانية)	ملخص الضابط الرقابي
الملاحظات			
من خلال مراجعة فريق التقييم لإجراءات إدارة الحوادث السيبرانية تم اختيار عدد (5) عينات من أصل (27) حادثة سيبرانية مسجلة لدى المجلس، وتمت مراجعة تقارير ما بعد الحادث (Post-Incident Reports) الخاصة بها. وتبين أنه تم إغلاق عدد (4) حوادث ضمن الإطار الزمني المحدد وفقاً لتصنيف الحادثة، في حين تم إغلاق حادثة واحدة بعد تجاوز الفترة الزمنية المحددة، بما يشير إلى عدم الالتزام الكامل بالأطر الزمنية المعتمدة لمعالجة الحوادث السيبرانية، وذلك بسبب ضعف حوكمة إدارة الحوادث السيبرانية.			
الأثر / الخطر المصاحب			
غياب خطة فعالة ومطبقة للاستجابة للحوادث السيبرانية قد يؤدي إلى ضعف في سرعة التعامل مع الحوادث واكتشافها، مما يزيد من احتمال توسع الأثر، مثل تسريب بيانات، أو تعطيل الأنظمة، أو التأثير على استمرارية الأعمال. كما أن عدم توثيق أو تحليل الحوادث يقلل من قدرة المؤسسة على التعلم والتحسين، ويؤثر على امتثالها للمتطلبات التنظيمية.			
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة	
30 - سبتمبر - 2026م	إدارة الأمن السيبراني	العمل على تفعيل آلية متابعة وتصعيد للحوادث المتأخرة، ومراقبة مؤشرات الأداء المتعلقة بزمان الاستجابة والمعالجة، مع تحليل أسباب التأخير واتخاذ الإجراءات التصحيحية اللازمة، وضمان الالتزام بمصفوفة التصنيف والأطر الزمنية المعتمدة.	



شبه فعال	ضوابط الأمن المادي والبيئي		15.
1.20	الرمز المرجعي	الضوابط الأساسية للأمن السيبراني: - ضابط 2-14-3: يجب أن تغطي متطلبات الأمن السيبراني لحماية الاصول المعلوماتية والتقنية للجهة من الوصول المادي غير المصرح به والفقدان والسرقة والتخريب بحد أدنى الدخول المصرح به للأماكن الحساسة في الجهة (مثل: مركز بيانات الجهة، مركز التعافي من الكوارث، أماكن معالجة المعلومات الحساسة، مركز المراقبة الأمنية، غرف اتصالات الشبكة، مناطق الامداد الخاصة بالأجهزة والمعدات التقنية، وغيرها). بالإضافة الى سجلات الدخول والمراقبة (CCTV) وحماية معلومات سجلات الدخول والمراقبة.	مرجع الضابط الرقابي
		تطبيق ضوابط الأمن المادي والبيئي على مركز البيانات	ملخص الضابط الرقابي
الملاحظات			
من خلال مراجعة فريق التقييم لضوابط الأمن المادي والبيئي، تبين ما يلي: - عدم وجود تقارير موثقة لعمليات المراجعة أو الصيانة الدورية للضوابط الأمنية المادية والبيئية الخاصة بمركز البيانات. - جهاز قياس درجة الحرارة والرطوبة داخل مركز البيانات غير مفعل. وذلك بسبب عدم وجود آلية معتمدة لإجراء ومتابعة الصيانة الدورية للضوابط الأمنية والبيئية.			
الأثر / الخطر المصاحب			
- عدم تطبيق ضوابط الأمن المادي والبيئي بشكل كافى وفعال قد تؤدي إلى تلف البيانات والأصول التقنية. - غياب قائمة معتمدة بالموظفين المخولين بدخول مركز البيانات قد يؤدي إلى دخول أشخاص غير مصرح لهم، مما يعرض الأنظمة والمعدات الحساسة لخطر العبث أو الوصول غير المشروع. - غياب الموافقات الرسمية لدخول مركز البيانات يضعف من الرقابة على عمليات الدخول، ويقلل من القدرة على تتبع المسؤوليات في حال وقوع حادث أمني أو خلل تقني.			
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة	
31 - ديسمبر - 2026 م	إدارة تقنية المعلومات	العمل على التالي: - إعداد واعتماد خطة زمنية للفحوصات والصيانة الدورية للضوابط الأمنية المادية والبيئية، تشمل توثيق نتائج الفحوصات، ومعالجة الملاحظات المكتشفة، واعتماد التقارير من الجهات المختصة، بما يضمن المتابعة المستمرة والالتزام بالضوابط المعتمدة. - تفعيل كاشف درجة الحرارة والرطوبة داخل مركز البيانات، والتأكد من تشغيله بكفاءة، وربطه بآلية متابعة دورية لضمان استمرارية عمله واكتشاف أي أعطال بشكل فوري.	

غير موجود	تدفق البيانات والتصاميم المعيارية للنظام المالي	16.
1.21	المنظمة العالمية للمعايير ISO27001 إدارة نظم أمن المعلومات: ضابط A.14.2.5 يركز على تأمين تصميم الأنظمة من خلال تطبيق ضوابط الحماية المناسبة أثناء تطويرها وصيانتها. يتطلب التأكد من أن بنية النظام تأخذ بعين الاعتبار حماية البيانات أثناء النقل والتخزين والمعالجة.	مرجع الضابط الرقابي
	توثيق تدفق البيانات والتصاميم المعيارية للنظام المالي للتحقق من كفاءة تصميم البنية التحتية.	ملخص الضابط الرقابي
الملاحظات		
من خلال مراجعة فريق التقييم للتصاميم المعمارية لأنظمة (المالية، والمستودعات، والمشتريات، والموارد البشرية)، تبين توفر بعض المخارج الجزئية، حيث تم الاطلاع على مخططات تدفق البيانات (Data Flow Diagrams) لنظام المالية، بالإضافة إلى مخطط تصميم تفصيلي منخفض المستوى (Low-Level Design - LLD) للبنية التحتية للشبكة يوضح آلية الربط بين مكونات الشبكة. إلا أنه لم يتم توفير وثيقة معمارية متكاملة للأنظمة (System Architecture Document)، تتضمن المعمارية عالية المستوى (High-Level Architecture) والمعمارية التفصيلية (Low-Level Architecture) لكل نظام، بما يوضح الهيكل الفني الشامل، وآلية تكامل الأنظمة مع بعضها البعض، وعلاقتها بالبنية التحتية الداعمة. ويشير ذلك إلى أن التوثيق المعماري المتوفر جزئي وغير مكتمل ولا يوفر رؤية شاملة للبيئة التقنية. وذلك بسبب غياب حوكمة توثيق المعمارية التقنية للأنظمة (المالية، والمستودعات، والمشتريات، والموارد البشرية).		
الأثر / الخطر المصاحب		
• انعدام وضوح تدفق البيانات مما قد يؤدي إلى أخطاء في التكامل بين الأنظمة المختلفة. • ضعف الأمن السيبراني بسبب سوء تصميم البنية التحتية مما يتيح فرصة للهجمات السيبرانية.		
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة
30 - يونيو - 2027م	إدارة تقنية المعلومات	العمل على التالي: • إعداد وثيقة معمارية شاملة للأنظمة (المالية، والمستودعات، والمشتريات، والموارد البشرية) تتضمن ما يلي: - المعمارية عالية المستوى (High-Level Architecture). - المعمارية التفصيلية (Low-Level Architecture). - مخططات تدفق البيانات (Data Flow Diagrams). - تصميم طبقات النظام (Presentation, Application, Data Layers). - توضيح مكونات النظام وآلية تكاملها والبنية التحتية الداعمة. • تضمين متطلبات دعم المرونة والتوسع (Scalability)، وضوابط الحماية الأمنية المناسبة ضمن التصميم المعماري، بما يتوافق مع أفضل الممارسات والمعايير المعتمدة. • اعتماد وثيقة المعمارية من قبل إدارة تقنية المعلومات والجهات ذات العلاقة.

ثالثاً: ملاحظات التقييم – العمليات الخاضعة للرقابة المالية



ثالثاً: ملاحظات التقييم - العمليات الخاضعة للرقابة المالية

شبه فعال	سجل الأصول الثابتة		17.
2.2	الرمز المرجعي	إطار الرقابة الداخلية COSO / الأنشطة لرقابية / اختيار وتطوير الأنشطة الرقابية.	مرجع الضابط الرقابي
		سجل محدث بالأصول الثابتة في الجهة يشمل بحد أدنى على (الأصل، رقم (رمز) الأصل المرجعي، تاريخ الشراء، تكلفة الأصل، اسم صاحب العهدة ...) بالإضافة إلى ترميز الأصول الثابتة وجردها بشكل دوري مره في السنة على الأقل	ملخص الضابط الرقابي
الملاحظات			
من خلال فحص ومراجعة سجل الأصول، تبين لفريق التقييم عدم وجود محاضر جرد الأصول وتم اختيار عدد (26) عينة للفحص حيث تبين عدم وجود بيانات لعدد (11) عينة. وذلك بسبب حادثة مشروع حصر وتقييم الأصول.			
الأثر / الخطر المصاحب			
- احتمالية ضعف عملية الرقابة والمتابعة على الأصول. - احتمالية فقدان الأصول وصعوبة إجراء الجرد الدوري أو السنوي.			
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة	
30 - يونيو - 2027م	الإدارة المالية	العمل على وجود وتوثيق محاضر للجرد بالإضافة إلى تحديث بيانات سجل الأصول.	



غير موجود	أوامر الصرف	18.
2.3	الرمز المرجعي	مرجع الضابط الرقابي إطار الرقابة الداخلية COSO / الأنشطة الرقابية / اختيار وتطوير الأنشطة الرقابية.
		ملخص الضابط الرقابي الفصل بين المهام ذات الطبيعة المتعارضة فيما يخص إعداد واعتماد أوامر الصرف (داخليا لدى الجهة وليس على منصة اعتماد) مع وجود الموافقات الملائمة.
الملاحظات		
من خلال فحص ومراجعة إجراءات فصل المهام لأمر الصرف، تبين لفريق التقييم أنه يمكن الجمع بين صلاحيتي اعداد ومراجعة أمر الصرف كما يمكن الجمع بين صلاحية المراجعة والاعتماد بالإضافة الى إمكانية الجمع بين كل المهام الثلاثة لمستخدم واحد. وذلك بسبب عدم وجود حوكمة للصلاحيات داخل النظام التقني.		
الأثر / الخطر المصاحب		
• احتمالية تجاوز أو سوء استغلال الصلاحيات المعتمدة داخل الجهة. • احتمالية هدر المال العام وعدم استغلاله بالشكل الأمثل. • احتمالية عدم كشف الأخطاء فور حدوثها.		
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة
30 - يونيو - 2027م	الإدارة المالية	العمل على فصل المهام المتعارضة عند إعداد ومراجعة واعتماد أمر الصرف وفق مصفوفة صلاحيات موثقة ومعتمدة.





صلاحية التعديل على أمر الصرف		غير موجود	19.
مرجع الضابط الرقابي	إطار الرقابة الداخلية COSO / الأنشطة الرقابية / اختيار وتطوير الأنشطة الرقابية.	الرمز المرجعي	2.4
ملخص الضابط الرقابي	عدم وجود صلاحية التعديل على أمر الصرف بعد اعتماده.		
الملاحظات			
من خلال فحص ومراجعة صلاحية التعديل على أمر الصرف، تبين لفريق التقييم إمكانية التعديل على أمر الصرف بعد اعتماده. وذلك بسبب عدم وجود حوكمة للصلاحيات داخل النظام التقني.			
الأثر / الخطر المصاحب			
- احتمالية هدر المال العام وعدم استغلاله بالشكل الأمثل. - احتمالية عدم كشف الأخطاء فور حدوثها لعمليات الصرف المتكررة.			
خطة عمل الإدارة	المسؤول عن التنفيذ	تاريخ التنفيذ	
العمل على تقييد صلاحية التعديل على أمر الصرف وفق مصفوفة صلاحيات موثقة ومعتمدة.	الإدارة المالية	30 – يونيو – 2027م	





تسجيل القيود المحاسبية		20.
غير موجود		
2.5	الرمز المرجعي	مرجع الضابط الرقابي إطار الرقابة الداخلية COSO / الأنشطة الرقابية / اختيار وتطوير الأنشطة الرقابية.
ملخص الضابط الرقابي		الفصل بين المهام ذات الطبيعة المتعارضة عند تسجيل القيود المحاسبية (بما يشمل قيود الإيرادات والمصروفات) مع وجود الموافقات الملائمة.
الملاحظات		
من خلال فحص ومراجعة تسجيل وترحيل القيود المحاسبية، تبين لفريق التقييم عدم وجود قيود على النظام فيما يخص الفصل بين مهمة إعداد (Preparation) واعتماد تسجيل / ترحيل (Posting) القيد المحاسبي. وذلك بسبب وجود مستوى واحد فقط وهو ترحيل قيد محاسبي.		
الأثر / الخطر المصاحب		
- احتمالية وجود صعوبة في معالجة الأخطاء المحاسبية عند الاقفاالات الشهرية والسنوية. - احتمالية عدم كشف الأخطاء فور حدوثها وصرف مبالغ غير مستحقة. - احتمالية وجود عمليات احتيال واستغلال للمال العام للأغراض الشخصية.		
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة
30 – يونيو – 2027م	الإدارة المالية	العمل على الفصل بين مهمة إعداد (Preparation) واعتماد تسجيل / ترحيل (Posting) القيد المحاسبي.





غير موجود	المطابقات الشهرية	21.
2.6	الرمز المرجعي	الفصل السابع: قواعد وإجراءات إقفال الحسابات. رابعاً: الايداعات والأرصدة النقدية الفقرة (2)، سادساً: الجداول الشهرية الفقرة (1) من تعليمات تنفيذ الميزانية العامة للدولة والتعليمات المالية والمحاسبية.
		ملخص الضابط الرقابي المطابقات الشهرية للحسابات وعمل التسويات اللازمة ومطابقة أرصدة الحسابات في الأستاذ العام مع الحسابات البنكية (التجارية / البنك المركزي).
الملاحظات		
من خلال فحص ومراجعة المطابقات الشهرية، تبين لفريق التقييم عدم وجود مطابقات شهرية للحسابات البنكية. وذلك بسبب عدم وجود اجراء موثق لعمليات المطابقات الشهرية.		
الأثر / الخطر المصاحب		
• احتمالية التأخر في إجراء القيود المحاسبية اللازمة. • احتمالية عدم دقة وصحة التقارير المالية. • احتمالية ظهور أرصدة غير صحيحة لبعض الحسابات. • احتمالية التأخر في إعداد الحساب الختامي.		
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة
30 - يونيو - 2027م	الإدارة المالية	العمل على الآتي: - مطابقات شهرية بين أرصدة الحسابات البنكية في دفتر الأستاذ العام وبين أرصدة الحسابات البنكية من واقع كشوفات الحسابات. - مطابقة شهرية بين أرصدة الإيرادات في دفتر الأستاذ العام وبين كشف الحساب التجميعي للجهة لدى البنك المركزي.



شبه فعال	العهد تحت التحصيل		22.
2.8	الرمز المرجعي	الفصل الخامس: الحسابات المحاسبية الأخرى. (الثاني عشر) من المادة (1) تعليمات السلف المؤقتة والسلف المستديمة. الفصل السابع: قواعد وإجراءات إقفال الحسابات. ثانياً: السلف والعهد. الفقرة (4) و (10) من تعليمات تنفيذ الميزانية العامة للدولة والتعليمات المالية والمحاسبية.	مرجع الضابط الرقابي
		سجل أعمار العهد تحت التحصيل ومتابعتها بشكل دوري وتحديد أسباب عدم تحصيلها.	ملخص الضابط الرقابي
الملاحظات			
من خلال فحص ومراجعة العهد، تبين لفريق التقييم عدم وجود توثيق لدراسة أسباب عدم التحصيل العهد. وذلك بسبب عدم وجود إجراء موثق ومعتمد للعهد تحت التحصيل ويشمل دراسة أسباب عدم تحصيلها.			
الأثر / الخطر المصاحب			
- احتمالية تضخم ارصدة حسابات العهد تحت التحصيل. - احتمالية تعرض الجهة لمخاطر عدم تحصيل مبالغ العهد تحت التحصيل.			
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة	
30 - يونيو - 2027م	الإدارة المالية	العمل على وجود إجراء موثق ومعتمد للعهد تحت التحصيل ويشمل دراسة أسباب عدم تحصيلها.	



شبه فعال	خطة المشتريات		23.
2.9	الرمز المرجعي	1. الفقرة (1) من المادة (12) من نظام المنافسات والمشتريات الحكومية. 2. المادة (3) من اللائحة التنفيذية لنظام المنافسات والمشتريات الحكومية.	مرجع الضابط الرقابي
		وجود خطة مشتريات موثقة ومعتمدة للرفع على منصة اعتماد.	ملخص الضابط الرقابي
الملاحظات			
من خلال فحص ومراجعة إجراءات إعداد خطة المشتريات، تبين لفريق التقييم أنه لم يتم أخذ احتياجات الإدارات أو الوكالات المختلفة بعين الاعتبار وذلك من خلال عدم وجود مراسلات مع الإدارة المعنية لعينة واحدة من أصل أربع عينات تم فحصها. وذلك بسبب عدم وجود إجراء موثق ومعتمد لإجراءات إعداد خطة المشتريات.			
الأثر / الخطر المصاحب			
- احتمالية تجاوز تكاليف المشتريات للميزانية المعتمدة نتيجة ضعف التخطيط. - احتمالية عدم مراعاة المزيج الثلاثي (السعر والجودة والخدمة) في صفقات الشراء.			
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة	
30 - يونيو - 2027م	إدارة المشتريات	العمل على أخذ احتياجات الإدارات أو الوكالات المختلفة بعين الاعتبار وذلك من خلال توثيقها خلال مراحل إعداد الخطة.	





شبه فعال	الموافقات الملائمة على اعتماد طلب المنافسة		24.
2.11	الرمز المرجعي	1 - إطار الرقابة الداخلية COSO / الأنشطة الرقابية / اختيار وتطوير الأنشطة الرقابية. 2 - المادة (54) من نظام المنافسات والمشتريات الحكومية.	مرجع الضابط الرقابي
		الالتزام بشروط تصنيف المنافسات، ووجود الموافقات الملائمة على ترسية المنافسة من اصحاب الصلاحية.	ملخص الضابط الرقابي
الملاحظات			
من خلال فحص ومراجعة إجراءات الالتزام بشروط تصنيف المنافسات، تبين لفريق التقييم عدم وجود خطاب أو قرار ترسية لعينة من أصل أربع عينات بالإضافة إلى عدم تزويدنا بالمستندات المطلوبة لعدد عيئتان مما يتعذر معه التحقق من سلامة إجراءات الالتزام بشروط تصنيف المنافسات. وذلك بسبب عدم وجود إجراء موثق ومعتمد.			
الأثر / الخطر المصاحب			
- احتمالية تجاوز أو سوء استغلال الصلاحيات المعتمدة داخل الجهة. - احتمالية وجود عمليات احتيال واستغلال للمال العام للأغراض الشخصية.			
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة	
30 - يونيو - 2027م	إدارة المشتريات	العمل على الالتزام بوجود خطاب او قرار الترسية عند ترسية المنافسات.	





شبه فعال	الموافقات الملائمة على التعميد		25.
2.12	الرمز المرجعي	1- إطار الرقابة الداخلية COSO / الأنشطة الرقابية / اختيار وتطوير الأنشطة الرقابية 2- الفقرة (4) من المادة (54) من نظام المنافسات والمشتريات الحكومية	مرجع الضابط الرقابي
		الالتزام بشروط تصنيف الشراء المباشر، ووجود الموافقات الملائمة على التعميد (أمر الشراء المباشر) من قبل أصحاب الصلاحية.	ملخص الضابط الرقابي
الملاحظات			
من خلال فحص ومراجعة إجراءات الالتزام بشروط تصنيف الشراء المباشر، تبين لفريق التقييم أنه تم التعميد لعينتان من أصل ثلاث عينات من قبل مدير عام الموارد المؤسسية دون وجود تفويض له من الأمين العام، حيث صلاحية الاعتماد للأمين العام بناءً على الفقرة التاسعة من المادة التاسعة لمصفوفة الصلاحيات الخاصة بالأمانة العامة، كما أنه لم يتم تزويدنا بمستندات العينة الثالثة. وذلك بسبب عدم وجود إجراء موثق ومعتمد.			
الأثر / الخطر المصاحب			
- احتمالية تجاوز أو سوء استغلال الصلاحيات المعتمدة داخل الجهة. - احتمالية عدم الوفاء باحتياجات المنظمة الأساسية والمناسبة.			
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة	
30 - يونيو - 2027م	إدارة المشتريات	العمل على التالي: - الالتزام بشروط تصنيف الشراء المباشر، ووجود الموافقات الملائمة على التعميد (أمر الشراء المباشر) من قبل أصحاب الصلاحية. - قرار تفويض صلاحيات في حال تم التفويض لصلاحية اعتماد تأمين الأعمال والمشتريات التي تبلغ (30) ألف ريال فأقل من قبل الأمين العام.	





شبه فعال	ادخال العقود في النظام		26.
2.13	الرمز المرجعي	إطار الرقابة الداخلية COSO / الأنشطة الرقابية / اختيار وتطوير الأنشطة الرقابية.	مرجع الضابط الرقابي
وجود الموافقات الملائمة على عملية ادخال العقود في النظام، والموافقات الملائمة على أوامر التغيير للعقود.			ملخص الضابط الرقابي
الملاحظات			
من خلال فحص ومراجعة إجراءات ادخال العقود والموافقات الملائمة على أوامر التغيير، تبين لفريق التقييم أنه لا يتم ادخال العقود على نظام تقني. وذلك بسبب عدم وجود نظام تقني لعمليات المشتريات والعقود			
الأثر / الخطر المصاحب			
- احتمالية تجاوز أو سوء استغلال الصلاحيات المعتمدة داخل الجهة. - احتمالية صعوبة كشف الأخطاء في عملية ادخال العقود.			
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة	
30 - يونيو - 2027م	إدارة المشتريات	العمل على انشاء نظام تقني لعمليات المشتريات والعقود وتقييد الصلاحيات عليه وفق مصفوفة صلاحيات موثقة ومعتمدة.	





شبه فعال	الفصل بين المهام الخاصة		27.
2.15	الرمز المرجعي	1- إطار الرقابة الداخلية COSO / الأنشطة الرقابية / اختيار وتطوير الأنشطة الرقابية. 2- المادة (2) من قواعد وإجراءات المستودعات الحكومية.	مرجع الضابط الرقابي
الفصل بين المهام الخاصة بمراقبة المخزون وعمليات إدارة المستودعات ونشاط المشتريات.			ملخص الضابط الرقابي
الملاحظات			
من خلال فحص ومراجعة الهيكل التنظيمي للجهة، تبين لفريق التقييم أن مهام المستودعات ومراقبة المخزون تتبع لإدارة الخدمات العامة. وذلك بسبب عدم وجود حوكمة لمهام المخزون والمستودعات في الجهة.			
الأثر / الخطر المصاحب			
- احتمالية تعارض المصالح بين كلا من نشاط المشتريات والمستودعات أو بين إدارة المستودعات ومراقبة المخزون. - سوء استغلال الصلاحيات الممنوحة للموظفين مما قد يؤدي إلى هدر المال العام.			
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة	
30 - يونيو - 2027م	إدارة الخدمات العامة	العمل على فصل مهام المستودعات عن مراقبة المخزون.	





غير موجود	الفصل بين المهام الخاصة		28.
2.16	الرمز المرجعي	1-المادة (4) من قواعد وإجراءات المستودعات الحكومية. 2-إطار الرقابة الداخلية COSO / الأنشطة الرقابية / اختيار وتطوير الأنشطة الرقابية.	مرجع الضابط الرقابي
		الفصل بين المهام عند استلام ومعاينة وتسجيل المخزون وصرفه مع وجود الموافقات الملائمة.	ملخص الضابط الرقابي
الملاحظات			
من خلال فحص ومراجعة النماذج المستودعية، تبين لفريق التقييم أنه لم يتم أتمتة النماذج المستودعية لعدد 15 عينة كما أنه لا يتم استخدام نماذج 2 و7. وذلك بسبب عدم حوكمة أعمال ومهام المستودعات ومراقبة المخزون.			
الأثر / الخطر المصاحب			
• احتمالية عدم كشف الأخطاء فور حدوثها أو فقدان الأصناف في المستودعات. • احتمالية سوء استغلال الصلاحيات الممنوحة للموظفين عند استلام ومعاينة وتسجيل المخزون وصرفه.			
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة	
30 - يونيو - 2027م	إدارة الخدمات العامة	العمل على أتمتة النماذج المستودعية واستخدام النماذج المستودعية وفق ما ورد في قواعد وإجراءات المستودعات الحكومية.	





29.		صلاحية التعديل على سجلات المخزون		غير موجود
مرجع الضابط الرقابي		1-المادة (38) من قواعد وإجراءات المستودعات الحكومية. 2-إطار الرقابة الداخلية COSO / الأنشطة الرقابية / اختيار وتطوير الأنشطة الرقابية.		الرمز المرجعي
ملخص الضابط الرقابي		عدم وجود صلاحية التعديل على سجلات المخزون (Masterfile).		
الملاحظات				
من خلال فحص ومراجعة إجراءات المخزون، تبين لفريق التقييم عدم وجود نظام آلي لدى إدارة مراقبة المخزون. وذلك بسبب عدم وجود نظام تقني في إدارة الخدمات العامة.				
الأثر / الخطر المصاحب				
- احتمالية سوء استغلال الصلاحيات الممنوحة للموظفين عند استلام ومعاينة وتسجيل المخزون وصرفه. - احتمالية صعوبة كشف الأخطاء وفقدان الأصناف وضعف إجراءات الضبط والرقابة على المخزون، مما قد يؤدي إلى هدر للمال العام.				
خطة عمل الإدارة		المسؤول عن التنفيذ		تاريخ التنفيذ
العمل على نظام تقني وربط عمليات المستودعات ومراقبة المخزون.		إدارة الخدمات العامة		30 – يونيو – 2027م





30.		تسجيل أصناف المخزون في المستودعات وإجراءات الجرد		غير موجود
مرجع الضابط الرقابي		المادة (38) من قواعد وإجراءات المستودعات الحكومية.		2.18
ملخص الضابط الرقابي		تسجيل وتكويد أصناف المخزون فى المستودعات وإجراء جرد سنوي للمخزون وتشكيل لجنة الجرد.		
الملاحظات				
من خلال فحص ومراجعة لعمليات تسجيل وتكويد الأصناف فى المخزون، تبين لفريق التقييم عدم وجود تكويد للأصناف فى مستودعات الجهة وعدم ربطها بسجل المخزون، كما أنه لا يوجد قرار تشكيل لجنة جرد للمستودعات ولا يوجد محضر للجرد. وذلك بسبب عدم وجود إجراء موثق ومعتمد.				
الأثر / الخطر المصاحب				
- احتمالية فقدان الأصناف وعدم معرفة الكميات الموجودة. - احتمالية عدم مقدرة الادارة على تحديد مستويات الطلب (الحد الأعلى والأدنى). - احتمالية صعوبة تلبية طلبات الإدارات والاقسام فى الوقت المناسب. - احتمالية تأخر عمليات الجرد الدورية والسنوية.				
خطة عمل الإدارة		المسؤول عن التنفيذ		تاريخ التنفيذ
العمل على التالى: - تكويد أصناف المخزون المختلفة سواء على النظام الآلى أو يدويا فى حال عدم وجود نظام آلى لدى المستودعات. - ربط المخزون داخل المستودع بالأكواد المستخدمة فى النظام الآلى / السجل اليدوي. - اعتماد قرار تشكيل لجنة الجرد من قبل صاحب الصلاحية ووجود ممثل مراقبة المخزون ضمن أعضاء لجنة الجرد. - تنفيذ عملية الجرد بشكل سنوي على الأقل للمخزون وتوثيقه بمحضر جرد ووجود الموافقات اللازمة على المحضر ووجود توثيق للإجراءات التصحيحية المقترحة لأي انحرافات رُصدت خلال الجرد.		إدارة الخدمات العامة		30 – يونيو – 2027م





شبه فعال	عملية الادراج للموظفين الجدد		31.
2.19	الرمز المرجعي	إطار الرقابة الداخلية COSO / الأنشطة الرقابية / اختيار وتطوير الأنشطة الرقابية	مرجع الضابط الرقابي
وجود الموافقات على عملية الادراج للموظفين الجدد من خلال النظام وفقاً لمصفوفة الصلاحيات وإدراج الموظفين الجدد ضمن مسير الرواتب بعد الاعتماد.			ملخص الضابط الرقابي
الملاحظات			
من خلال فحص ومراجعة إجراءات ادراج الموظفين الجدد على النظام، تبين لفريق التقييم عدم وجود إجراءات أو مصفوفة صلاحيات للفصل بين المهام الخاصة بإضافة الموظف الجديد (سلسلة موافقات). وذلك بسبب عدم وجود اجراء لدعم النظام الآلي وتفعيل خاصية الفصل بين المهام.			
الأثر / الخطر المصاحب			
- احتمال اتخاذ قرارات لا تتناسب مع طبيعة العمل. - احتمالية تجاوز الصلاحيات المعتمدة داخل الجهة. - احتمالية صرف مبالغ غير مستحقة للموظفين الجدد.			
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة	
30 - يونيو - 2027م	إدارة الموارد البشرية	العمل على إجراءات أو مصفوفة صلاحيات للفصل بين المهام الخاصة بإضافة الموظف الجديد (سلسلة موافقات) والالتزام بتنفيذها على النظام.	





شبه فعال	مسيرات الرواتب		32.
2.20	الرمز المرجعي	إطار الرقابة الداخلية COSO / الأنشطة الرقابية / اختيار وتطوير الأنشطة الرقابية.	مرجع الضابط الرقابي
الفصل في المهام بين عملية إعداد ومراجعة واعتماد مسيرات الرواتب والمكافآت، وتقييد صلاحيات التعديل والحذف على ملفات المسيرات مع تشفيرها لتقييد صلاحية الاطلاع عليها.			ملخص الضابط الرقابي
الملاحظات			
من خلال فحص ومراجعة إجراءات فصل المهام في مسيرات تعويضات العاملين، تبين لفريق التقييم عدم وجود إجراءات أو مصفوفة صلاحيات توضح صلاحية الحذف أو الإضافة لمسير الرواتب (سلسلة موافقات)، كما أنه لا يتم تشفير مسار الرواتب ولا تقييد صلاحية الاطلاع عليه. وذلك بسبب عدم وجود إجراء لدعم النظام الآلي وتفعيل صلاحية الحذف أو الإضافة لمسير الرواتب أو تشفيرها.			
الأثر / الخطر المصاحب			
- احتمالية سوء استغلال الصلاحيات الممنوحة للموظفين على مسيرات الرواتب. - الصرف بالزيادة أو النقص خطأ وإهدار المال العام.			
تاريخ التنفيذ	المسؤول عن التنفيذ	خطة عمل الإدارة	
30 - يونيو - 2027م	إدارة الموارد البشرية	العمل على التالي: - إجراءات أو مصفوفة صلاحيات توضح صلاحية الحذف أو الإضافة لمسير الرواتب (سلسلة موافقات). - تشفير مسار الرواتب وتقييد صلاحية الاطلاع عليه.	





33.		التعديل على السلم الوظيفي		غير موجود
مرجع الضابط الرقابي		إطار الرقابة الداخلية COSO / الأنشطة الرقابية / اختيار وتطوير الأنشطة الرقابية.		الرمز المرجعي
ملخص الضابط الرقابي		ملائمة الصلاحيات الممنوحة على النظام فى التعديل على السلم الوظيفى والفصل بين المهام عند التعديل.		
الملاحظات				
من خلال فحص ومراجعة صلاحيات التعديل على السلم الوظيفى، تبين لفريق التقييم عدم وجود إجراءات أو مصفوفة صلاحيات توضح صلاحية التعديل على السلم الوظيفى على النظام. وذلك بسبب عدم وجود اجراء لدعم النظام الالى وتفعيل صلاحية التعديل على السلم الوظيفى.				
الأثر / الخطر المصاحب				
- احتمالية تجاوز أو سوء استغلال الصلاحيات المعتمدة داخل الجهة. - احتمالية اتخاذ القرارات ليست من مصلحة العمل. - احتمالية تجاوز الاسقف المالية المعتمدة.				
خطة عمل الإدارة		المسؤول عن التنفيذ		تاريخ التنفيذ
العمل على إجراءات أو مصفوفة صلاحيات توضح صلاحية التعديل على السلم الوظيفي على النظام.		إدارة الموارد البشرية		30 – يونيو – 2027م



رابعاً: أنشطة إدارة التغيير



رابعاً: أنشطة إدارة التغيير في عملية التحول للرقابة الذاتية

سعيًا من وزارة المالية لتحقيق أهداف التحول إلى الرقابة الذاتية ودعم وتمكين الجهات الحكومية لتبني التغيير المصاحب لرحلة التحول وتسهيل عملية انتقال الجهة الحكومية ومنسوبيها من الوضع الراهن إلى الوضع المستقبلي، تم العمل على أنشطة إدارة التغيير والتي تهدف إلى:

- تعزيز الرغبة في تبني التغيير وتطبيق الرقابة الذاتية
- بناء قدرات الموظفين المعنيين في الجهات الحكومية
- رفع مستويات الوعي لدى الجهات الحكومية لتطبيق الرقابة الذاتية
- تعزيز الدعم من رعاة التحول في الجهات الحكومية

■ المحاور الرئيسية لأنشطة إدارة التغيير

❖ المحور الأول: التواصل

يعنى هذا المحور بالعمل على رفع الوعي وتعزيز رغبة منسوبي الجهة بالتحول وتبنيه من خلال الآتي:

- عقد عدد من ورش العمل التعريفية لأصحاب المصلحة من الإدارات المستهدفة لهدف التعريف بالتحول والدور الرقابي للوزارة ومهامهم ومسؤولياتهم كممكنين وداعمين للتحول كالتالي:

1. الورشة التعريفية لسفراء التغيير
2. الورشة التعريفية للمديرين والمشرفين

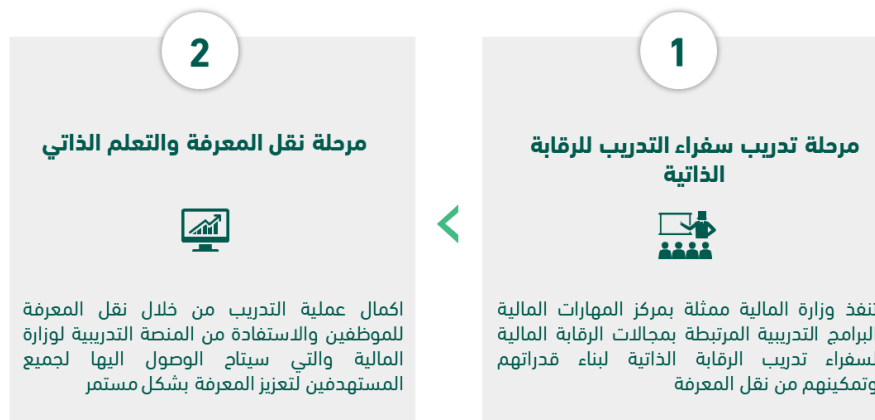
- إطلاق عدد من الحملات الإعلانية لتعزيز الوعي عن التحول وشملت مواد ترويجية متنوعة مثل النشرات والانفوجراف والمشاهد المرئية (فيديو) وشاشات الاقفال واللوحات الاعلانية، وهي:

الحملة الإعلانية	حالة الحملة
الحملة التعريفية بالتحول	تم الاطلاق
الحملة التثقيفية	جاري الاطلاق
حملة أثر التغيير	سيتم اطلاقها بعد اصدار التقرير النهائي لمستوى الكفاءة الرقابية
حملة التعزيز والاستدامة	سيتم الاطلاق بعد انتهاء الجهة الحكومية من تنفيذ الخطة التصحيحية والتحول إلى الرقابة الذاتية

❖ المحور الثاني: التدريب

ضمن جهود وزارة المالية في دعم تحول الجهة الحكومية نحو تطبيق الرقابة الذاتية، عملت على منهجية للتدريب تستند على مسارين رئيسيين بهدف تمكين منسوبي الجهة من تطبيق مفاهيم الرقابة المالية بفاعلية على النحو التالي:

- **التدريب بمجالات الرقابة المالية:** يعنى هذا المحور بالعمل على بناء قدرات سفراء التدريب للرقابة الذاتية بهدف رفع المعرفة بأفضل الممارسات في مجالات الرقابة المالية من خلال استراتيجية للتدريب والتي تتضمن:



• مرحلة تدريب سفراء التدريب للرقابة الذاتية:

- بدأت وزارة المالية ممثلة بمركز المهارات المالية الترتيبات اللازمة مع ضابط الاتصال (قائد سفراء التغيير) لترشيح عدد (6) من منسوبي الجهة كسفراء للتدريب للرقابة الذاتية بهدف عقد ورش عمل تدريبية متخصصة في مجالات الرقابة المالية والتي تبنى على مسارين وهي: (مسار الرقابة والمراجعة الداخلية - مسار الحوكمة والمخاطر والالتزام).

• مرحلة نقل المعرفة والتعلم الذاتي:

- ستكون الجهة الحكومية مسؤولة عن استكمال عمليات التدريب وبناء القدرات في مجالات الرقابة المالية لمنسوبيها من الإدارات المعنية بالتحول، ونقل المعرفة من خلال الاستفادة من تمكين سفراء التدريب للرقابة الذاتية او المنصة التدريبية والتي سيتم اطلاقها من قبل وزارة المالية لاستكمال عمليات التدريب لمنسوبي الجهة لديكم.



❖ المحور الثالث: القياس والمتابعة

يعنى هذا المحور بتفعيل شبكة المؤثرين من رعاة التحول وسفراء التغيير والذي تم اعتمادهم من قبل راعي التحول بالجهة وهم:

1- محمد الشريف (قائد سفراء التغيير)

2- فيصل الزهير (سفير تغيير)

وقد تم العمل بتنفيذ أنشطة هذا المحور من خلال التالي:

- عقد الاجتماع الافتتاحي مع المعنيين في الجهة ووزارة المالية للتعريف عن التحول ومنهجية العمل وبدء انطلاقة الأعمال.
- عقد اجتماعات دورية مع سفراء التغيير لتوضيح نسبة التقدم في الأعمال والأنشطة المتعلقة بمنهجية عمل التحول الى الرقابة الذاتية
- تزويد رعاة التحول بالتقارير الدورية التفصيلية التي توضح نسبة التقدم في الاعمال المرتبطة بالتحول الى الرقابة الذاتية وبالإمكان الرجوع الى التقارير الدورية للمزيد من التفاصيل.



خامساً: الخطة الزمنية لرفع مستوى الكفاءة الرقابية





خامساً: الخطة الزمنية لرفع مستوى الكفاءة الرقابية

تهدف الخطط التصحيحية المتفق عليها خلال عملية التقييم إلى رفع مستوى الكفاءة الرقابية في الأمانة العامة للمجلس الصحي السعودي، ومسؤولية تنفيذها تقع على عاتق الإدارات المعنية بالأمانة العامة، كما أن الجدول أدناه يوضح الخطة الزمنية المتفق عليها لتنفيذها مع عدد الخطط التصحيحية حسب الفترة:

تاريخ بداية مرحلة تنفيذ الخطط التصحيحية	1 - يوليو - 2026م
تاريخ تنفيذ الخطة التصحيحية	عدد الخطط المتفق على تنفيذها
الربع الثالث من العام 2026م	2 خطط تصحيحية
الربع الرابع من العام 2026م	3 خطط تصحيحية
الربع الثاني من العام 2027م	28 خطط تصحيحية
إجمالي عدد الخطط التصحيحية	33 خطة تصحيحية
التاريخ المتوقع للوصول إلى مستوى الكفاءة الرقابية المطلوب	30 - يونيو - 2027م

يوصي فريق عمل تقييم مستوى الكفاءة الرقابية بضرورة تنفيذ الخطط التصحيحية خلال المدد الزمنية المتفق عليها لغرض رفع مستوى الكفاءة الرقابية والوصول للمستوى المطلوب للتحويل للرقابة الذاتية، كما يجب التأكيد على أهمية رفع أي تحديات أو معوقات قد تواجه الإدارات المعنية بالأمانة العامة للمجلس الصحي السعودي في تنفيذ الخطط التصحيحية إلى فريق عمل تقييم مستوى الكفاءة الرقابية. وفي حال الحاجة القصوى لرفع طلب تمديد لتواريخ التنفيذ المتفق عليها يمكن الرجوع لمنهجية رفع طلبات التمديد ضمن ملحق رقم (1).



سادساً: الملحقَات

ملحق (1): منهجية تصعيد التأخر في تنفيذ الخطط التصحيحية ورفع طلبات التمديد

1. الآلية المعتمدة لتصعيد التأخر في تنفيذ الخطط التصحيحية المتفق عليها

آلية التصعيد في تنفيذ الخطة التصحيحية



2. الآلية المعتمدة لطلبات تمديد تواريخ تنفيذ الخطط التصحيحية المتفق عليها

آلية تمديد تنفيذ الخطة التصحيحية



ملحق (2): إطار تقييم مستوى الكفاءة الرقابية

إطار تقييم مستوى الكفاءة الرقابية

(1) إطار تصنيف كفاءة الضوابط الرقابية

(1) ضابط رقابي غير موجود	(2) ضابط رقابي شبه فعال	(3) ضابط رقابي فعال
لا يتوفر تصميم وتطبيق للضابط الرقابي اللازم في العملية / النشاط محل التقييم.	- يوجد ملاحظات على مستوى فعالية أو تصميم الضابط الرقابي - يوجد قصور في الالتزام بتطبيق الضابط الرقابي	- لا يوجد أي ملاحظات على مستوى تصميم وفعالية الضابط الرقابي - يتم الالتزام بتطبيق الضابط الرقابي بشكل كلي

(2) إطار تصنيف كفاءة الأنشطة / العمليات المرتبطة بالضوابط الرقابية

غير مرضي (% 0 - % 59)	يحتاج إلى تحسين (% 60 - % 99)	مرضي (% 100)
يوجد ملاحظات على تصميم أو فعالية أو الالتزام بتطبيق العديد من الضوابط الرقابية، مما أدى إلى ضعف درجة الكفاءة الرقابية في العملية / النشاط، حيث يجب البدء بتطبيق الخطط التصحيحية اللازمة لرفع درجة الكفاءة الرقابية.	يوجد بعض الملاحظات على تصميم أو فعالية أو الالتزام بتطبيق بعض الضوابط الرقابية، حيث تحتاج العملية / النشاط إلى المزيد من التحسين من خلال تطبيق الخطط التصحيحية اللازمة للوصول إلى درجة الكفاءة الرقابية المطلوبة.	لا يوجد أو تم ملاحظة وجود بعض الملاحظات البسيطة على تصميم أو فعالية أو الالتزام بتطبيق بعض الضوابط الرقابية، والتي لم تؤثر بشكل كبير على درجة الكفاءة الرقابية المطلوبة بالعملية / النشاط.

(3) نطاقات التحول للرقابة الذاتية

عدم إمكانية التحول للرقابة الذاتية	إمكانية التحول الجزئي للرقابة الذاتية	إمكانية التحول الكلي للرقابة الذاتية
- عدم تحقيق معدل 100% في أي من العمليات الخاضعة للرقابة المالية. - عدم تحقيق معدل 100% في محور فعالية الإدارات الرقابية والضوابط العامة لتقنية المعلومات.	- تحقيق معدل 100% في بعض العمليات الخاضعة للرقابة المالية. - تحقيق معدل 100% في محور فعالية الإدارات الرقابية والضوابط العامة لتقنية المعلومات.	- تحقيق معدل 100% في جميع العمليات الخاضعة للرقابة المالية. - تحقيق معدل 100% في محور فعالية الإدارات الرقابية والضوابط العامة لتقنية المعلومات.

نهاية التقرير

